

Setnayan — Privacy Compliance Dossier

For submission to the National Privacy Commission (NPC), Republic of the Philippines

Status: DPO-prepared submission draft — pending final external legal review before filing. This dossier is prepared by the Data Protection Officer to support NPC registration and to serve as Setnayan's Records of Processing Activities (ROPA) and Privacy Impact Assessment (PIA). It is reasoned from RA 10173 (Data Privacy Act of 2012), its IRR, and NPC issuances. It is **not legal advice**; the Personal Information Controller should have it reviewed by external counsel before submission.

Prepared: 2026-07-12. **Version:** 2.0 (last updated **2026-07-13**). **Governing law:** RA 10173 + IRR + NPC Circulars.

■ **DO NOT LODGE — three defects open (2026-07-20).** A compliance pass this session found three statements in this draft that do not match the shipped system, all verified against `origin/main @ 5b72d625d`. Corrections, drafted replacement text, and the resolutions the owner/DPO must pick are in [Papic Compliance Delta 2026-07-20.md](#). In summary: (1) §8a :170 tells the NPC full-res is kept 6 months while the shipped constant is 90 days, and calls the compressed copy retention "*indefinitely*" against the 5-year media period in the filed Data Retention Schedule (Delta §1 — this also blocks all retention marketing copy); (2) the ROPA has no row for Papic-captured photographs and clips — media collected on real events today (drafted row 21 at Delta §2.2, [PENDING DPO]); (3) §11 item 7 + ROPA row 20 tell the regulator the Papic Lite pool "*is built but flag-OFF*" — it does not exist (zero code matches) and the product was cancelled 2026-07-20 (Delta §3). None of these establishes unlawful processing; all three are accuracy defects in an unlodged draft, and all three are document edits. A fourth item — whether the RSVP consent copy actually names guest-phone capture and face-sorted delivery — is recorded for DPO ruling at Delta §4.

What changed in v2.0 (2026-07-13): the ROPA (§3) and the sensitive-personal-information declaration (§5) were expanded from a customer-centric, biometric-only scope to cover **every category the platform actually processes** — self-profile religion / civil status / gender, the dependents & godparents family graph (minors' data), event honoree / specialty data (incl. christening child data and gender-reveal due-date), e-gift receiving handles, and the vendor-verification identity surface. The subprocessor list (§7) was completed (Persona, TikTok, Suno added). Retention (§3, §8a) was aligned to the **Data Retention Schedule (2026-07-11)** with its statutory floors. Driven by the reconciliation in [Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md](#). Items still requiring owner/counsel action are consolidated in §11.

1. Personal Information Controller (PIC) and Data Protection Officer (DPO)

Field	Detail
Registered business name	SETNAYAN SOFTWARE DEVELOPMENT SERVICE

Legal form	Sole proprietorship (DTI-registered 2026-06-25, national scope)
PIC under RA 10173	The proprietor. A sole proprietorship has no legal personality separate from its proprietor, so the proprietor is the Personal Information Controller.
Data Protection Officer	The proprietor (Indalecio S. Casasola II), serving the DPO function directly
DPO contact	dpo@setnayan.com (the contact published on every public surface — privacy notice, cookie policy, acceptable-use, site footer, and schema.org metadata. Older internal/corpus documents that still list <code>iscasasolai@gmail.com</code> are to be aligned to this address — see §11.)
Data subject response SLA	15 business days (the period published in the live privacy notice. The older binding Privacy & Security Policy §9 states 7 business days and is to be reconciled up to 15 — see §11.)
BIR registration	Under the proprietor's existing TIN
NPC registration	To be filed under the registered business name
Public privacy notice	Published at <code>setnayan.com/privacy</code> (effective 2026-05-13; last updated 2026-07-13 via app PR #3215, adding the faith / family / honoree / e-gift disclosures + Anthropic/Suno subprocessors). The opt-in biometric and device-identifier sections were already present on <code>origin/main</code> .

2. Description of the Data Processing System

Setnayan is a Philippines-first life-events platform (V1 surface: weddings, with additional event types — birthday, debut, christening, gender reveal, anniversary, reunion, corporate and others — progressively enabled). It provides three role-routed doorways:

- **Couples / customers** plan an event end-to-end (guest lists, vendors, budget, schedule, invitations, media galleries) and optionally record personalization and family-milestone details.
- **Vendors** run a business profile, submit verification documents, and receive inquiries.
- **Administrators** (the Setnayan team) run operations, payment reconciliation, and integrity / fraud review.

Personal data is processed to deliver the planning service, to enable couple↔vendor communication, to process in-app payments, to verify vendor legitimacy, and to protect the marketplace from fraud. Processing is web-based; data resides with the subprocessors in §7.

3. Records of Processing Activities (ROPA)

Personal-data categories, purposes, legal bases, and retention. Retention detail is maintained in the companion **Data Retention Schedule (2026-07-11)**; periods marked (*counsel*) await external ratification. **Build-state** column: *Active* = collected in production now; *Gated* = shipped behind a feature flag; *Dormant* = built but not yet collecting.

#	Data category	Data subjects	Purpose	Legal basis (RA 10173)	Retention	Build-state
1	Account / profile — email, hashed password, display name, optional phone, profile photo	Couples, vendors, admins	Account creation + authentication; deliver the service	§ 12(a) consent; § 12(b) contract	Life of account + 30-day soft-delete tail, then purge	Active
2	Self-profile personalization — religion, civil status, gender/sex (<i>sensitive PI</i>) + per-field consent timestamps (religion_consent_at, civil_status_consent_at, sex_consent_at)	Account holders (adults)	Optional personalization — faith-appropriate suggestions, event-type relevance, salutation. Reference-only; not required to use the service	§ 13(a) explicit consent (self-provided, timestamped; withdrawable)	Life of account; cleared on withdrawal or account deletion	Active (self opt-in; no feature flag)
3	Event data — guest lists, vendor records, budget items, schedule, mood-board palettes	Couples (and guests they enter)	Deliver event-planning features the user is paying for	§ 12(b) contract	5 years from event date (<i>counsel</i>)	Active
4	Event honoree / specialty details — e.g. christening child name, birth date, gender + rite; gender-reveal parents' names + expected due-date ; birthday celebrant name + age; debut celebrant; wedding ceremony rite (<i>contains sensitive PI + minors' data — see §5</i>)	Couples; the named honoree (may be a minor or a non-account third party)	Configure the specific event the couple is planning	§ 12(b) contract; § 13(a) consent of the enrolling account holder / guardian for the honoree's sensitive attributes	With the event record, 5 years from event date (<i>counsel</i>)	Active (in <code>events.signature_details</code> ; no feature flag, no separate consent timestamp — documented as-is; see §11)

5	Family graph — dependents & godparents. A dependent is a person, a pet, or anything the user cares for (dependent_kind). Only the person kind may carry name + birth date, sex, religion (+ guardian-consent timestamps) under the age fence; pet / other carry only a name + optional birthday — no sensitive data. Godparent: name, email (a third party), role, reminder preference	Account holder; their person-dependents (which may be a minor or an elder); godparents (third parties)	Optional milestone tracking (upcoming faith rites, godchild-birthday reminders)	§ 12(b) contract; § 13(a) guardian consent (timestamped) for a person-dependent's sensitive attributes; § 12(f) legitimate interest for godparent reminders	Life of account; deleted on withdrawal / account deletion. A person-child shared record is readable by a spouse account under a household model and retained after separation for continued co-parenting access (owner-defined)	Enabled in production (owner/DPO flipped NEXT_PUBLIC_DEPENDENT_PEOPLE 2026-07-16). Ownership transfer at majority (2026-07-16/17): a person-dependent's record can be CLAIMED by the data subject at 18 (RA 6809 age of majority — 18 for both sexes, distinct from the 18F/21M debut celebration ladder) via a single-use, 7-day, guardian-revocable link (bearer token; excluded from data exports; optionally emailed to a recipient address that is used once and stored nowhere). On claim, ownership of the record moves to the data subject — they gain full control including erasure; the former guardian retains read-only history; the record thereafter survives the guardian's account deletion and is deleted with the SUBJECT's account. Elders (already past majority) are claim-eligible from day one. Pet/other records never convert to an account; care can only be reassigned guardian→guardian. Godparent edges transfer with the claimed record.
---	---	--	--	---	--	---

6	In-app messages — couple↔vendor chat	Couples, vendors	Enable coordination between parties	§ 12(b) contract	5 years from event date (<i>counsel</i>)	Active
7	Payment metadata — order amounts, reference codes, channel, payment-proof screenshots	Paying users	Process + reconcile in-app payments; issue Official Receipts	§ 12(c) legal obligation (NIRC / BIR)	10 years — legal floor (BIR RR 17-2013)	Active
8	E-gift receiving methods (Pabuya) — the couple's own GCash / Maya / bank / PayPal handle, account name, and uploaded receiving-QR image	Couples	Display the couple's own gift-receiving details to their guests. Setnayan never holds, routes, or records the movement of money — the schema stores no amount, ledger, or settlement state	§ 12(b) contract (couple's own display data)	With the event record; deletable by the couple anytime	Active (public guest route reported enabled in production 2026-07-13)
9	Contracts + e-signatures	Couples, vendors	Vendor engagement records	§ 12(c) legal obligation; Civil Code Art. 1144	10 years — legal floor	Active
10	Vendor-verification identity data — government ID, business permits / registrations, and (where applicable) liveness selfie and sanctions / PEP screening result (<i>sensitive PI</i> — see §5)	Vendors (business owners)	Verify vendor legitimacy before a profile is trusted; marketplace safety	§ 12(b) contract; § 12(c)/(f) (fraud + AMLA-adjacent diligence)	Verification documents 90 days hot → cold retention to the statutory floor (<i>counsel</i>)	Active (documents collected; automated verification via Persona is staged — see §7)

11	Biometric — facial-geometry vectors (<i>sensitive PI</i>)	Guests/users who opt in (adults 18+)	Optional automatic photo-matching within a single event	§ 13(a) explicit opt-in consent , timestamped at enrolment	Per-event only; never reused across events; revocable on request. Facial-geometry vector auto-expired (nulled) at ~5 years by a scheduled per-event sweep (anchor = later of event date / enrolment); the underlying photo is retained. Selfie-asset purge-at-expiry is a DPO decision — §11	Built; vector storage Dormant (enrolment image-only until the matching model activates) — see §5
12	Device identifier — one-way hashed, first-party per-browser id	Signed-in users	Fraud prevention — detect fake / duplicate / sock-puppet accounts	§ 12(f) legitimate interest (fraud prevention + protecting vendors)	Life of account; rolling-prune device rows unused > 24 months (<i>counsel</i>)	Dormant — flag NEXT_PUBLIC_DEVICE_FING OFF in production; collects nothing pending DPO activation (§4)
13	Guest RSVP details — name, contact, meal preference / dietary restrictions (<i>health-adjacent</i>), plus-one, photo/face-recognition preferences	Guests entered/invited by the couple	Deliver RSVP, seating, catering counts, and media-tagging preferences	§ 12(b) contract; § 13(a) consent for dietary/health-adjacent + face-recognition preferences	With the event record, ≤5 years (<i>counsel</i>)	Active
14	Automatic technical data — IP address (truncated to first 3 octets for QR-scan events), browser user-agent, timestamps	Site visitors	Security, abuse-prevention, service operation	§ 12(f) legitimate interest	Provider default / with related record	Active

15	Product analytics — page views, clicks, funnel events (PostHog; no personal identifiers; opt-in via cookie consent)	Site visitors	Product improvement	§ 12(a) consent (cookie-consent gated; opt-out in profile)	Provider default	Active
16	Error/diagnostic logs — stack traces (Sentry; no message bodies, payment details, or guest data)	N/A (no PII by design)	Bug diagnosis + reliability	§ 12(f) legitimate interest; data-minimization	≤ 90 days	Active
17	Marketing consent / communication preferences (+ marketing_consent_at)	Couples, vendors	Proof of consent; honor preferences	§ 12(a) consent	Life of account + audit tail	Active
18	Support tickets	Users who contact support	Handle support requests	§ 12(b)/(f)	2 years	Active

19	Samahan (group) memberships — the group's user-chosen name, optional description, the member's role (organizer/member), join date, and a rotating invite token. No classification/category field exists by design (owner 2026-07-17): the platform never labels a group's nature or affiliation — the old kind taxonomy (which included parish, a religious-affiliation signal) was removed at the schema level, so no query, export, or breach can enumerate members by group type. A group's free-text name is the group's own speech, not a platform-assigned category	Account holders who create or join a samahan	User-initiated group formation (barkada/clan/org/etc as THEY name it); rosters visible to fellow members only	§ 12(b) contract (user-initiated membership)	Membership row deleted on leaving the group or account deletion; included in the data export (samahan_member	Active (live product); disclosed in the privacy notice "Samahan (groups)" section (2026-07-17)
----	--	--	---	--	--	--

~~20~~	■ WITHDRAWN 2026-07-20 — NEVER BUILT, PRODUCT CANCELLED. Do not lodge this row. The flag named below (NEXT_PUBLIC_PAPIC_LITE_ENABLED) does not exist in the codebase — zero matches across apps/web + supabase @ origin/main 5b72d625d — and the product was cancelled 2026-07-20 before any processing occurred. Replacement note + rationale: Papic Compliance Delta 2026-07-20.md §3. ■ "Papic Lite" also names a SHIPPED vendor on-the-day tier and a quality alias — see Delta §3.3 before deleting anything by name. Original row text follows for lineage: Papic Lite — open/crowd photo capture (public-event QR; photos only, no video, biometric-free — no facial-geometry vectors). A shared photo pool for a large public event; captures photographs that may include non-participant bystanders; optional participant join email (magic-link claim) + consent timestamp + device/IP-hash (Sybil control)	Public-event attendees + bystanders; the hosting organizer (controller of the pool)	Let a host collect one shared photo pool for a public/large event (concert, tournament, corporate); each joiner keeps their own shots	§ 12(b) contract (host); § 12(a) join-consent (participants); bystander images on a public-space + posted-host-notice basis (<i>counsel</i>)	Full-res 6-month window then dropped; compressed gallery ≤5y. Erasure = a public takedown/complaint form (routes to host + admin) — the subject-access mechanism <i>because Lite has no face-search</i>	Gated — NEXT_PUBLIC_PAPIC_LITE_ OFF in production; collects nothing until enabled, blocked on DPO + external-counsel sign-off + a CSAM matcher (see §11)
---------------	---	--	--	---	--	---

■ **ROPA GAP (2026-07-20) — a row is MISSING.** No row above covers the **photographs and ≤5-second clips** **Papic captures on guest and shooter phones** — row 3 ("Event data") does not name media, row 11 is the biometric vector, row 13 is an RSVP preference, and row 20 is withdrawn. This media is being collected on real events today. A drafted **row 21** (purpose, lawful basis, categories, subjects, retention, recipients, build-state) is at [Papic Compliance Delta 2026-07-20.md](#) §2.2, marked **[PENDING DPO]**.

Right-to-erasure interaction: an account-deletion request deletes the subject's personal data **except** records under a legal-hold floor (rows 7 & 9 — payments and contracts), which are retained under the legal-obligation basis for the statutory period and then disposed of. This carve-out is disclosed in the privacy notice. (*Known remediation: account hard-delete does not yet purge chat-message PII — tracked in §11 and the Data Retention Schedule §4.*)

4. Privacy Impact Assessment — Device-Fingerprint Capture (fraud prevention)

A PIA of the **newest and most scrutiny-worthy** processing activity (ROPA row 12). Built into the platform but **switched OFF behind a feature flag**; it collects nothing until the DPO authorizes activation. (*As of 2026-07-13 the flag `NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED` is confirmed OFF in production. A separate draft Anti-Fraud Policy amendment references this processing as active from 2026-07-07; that statement is ahead of the actual flag state and is being corrected — see §11.*)

4.1 What is processed and why

To protect couples and vendors from coordinated fraud (a single bad actor — often a competing vendor — spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer an inquiry), Setnayan must recognize when several "different" accounts are in fact the **same device**. On a signed-in session, the browser generates a **random identifier** stored in local storage; it is transmitted to Setnayan's server and **one-way hashed (SHA-256 with a server-side salt)**. Only the hash is stored, against the account. Two accounts sharing a device produce the same hash, which lets the existing fraud-clustering logic **flag them for human review** — it never auto-bans anyone.

4.2 Necessity and proportionality

- **Necessary:** vendors are charged per inquiry; fake inquiries are a direct, quantifiable financial harm, and account-level signals alone cannot detect one actor behind many accounts.
- **Proportionate / least-intrusive:** the signal is a **random id**, deliberately **not** a behavioral or biometric fingerprint (no canvas/font/WebGL probing) and uses **no third-party tracking SDK**. It identifies a *browser*, not a person's activity, and is never used for advertising, personalization, or cross-site tracking.

4.3 Legal basis

Legitimate interest under § 12(f): preventing fraud and protecting the marketplace and its vendors. Balancing test — the intrusion is minimal (a fraud-only pseudonymous hash), the interest is substantial, and the practice is disclosed. The data is **not** sensitive personal information.

4.4 Risks and mitigations

Risk	Mitigation
Re-identification of an individual	Value is a one-way hash of a random id (raw value never stored); pseudonymous; no linkage to browsing behavior
Function creep (used beyond fraud)	Purpose limitation enforced in code + policy; used only for identity-cluster fraud review; never sold or shared

Over-collection	Signed-in accounts only ; one hash per (account, device) + a last-seen timestamp; no IP stored for this signal
Data-subject unawareness	Already disclosed in the public privacy notice (the "Device identifier (fraud prevention)" section), ahead of activation
Unlawful retention	Retention clock (life of account; rolling-prune > 24 months); included in data export; deleted on account deletion
Activation without oversight	Flag-gated OFF ; activation requires DPO sign-off; fully reversible from a single toggle

4.5 Residual assessment

With the above controls, residual privacy risk is **LOW**. The privacy-notice disclosure is already published; the remaining gate is the DPO's activation decision.

5. Sensitive Personal Information (RA 10173 § 13)

RA 10173 § 3(l) / § 13 treats as **sensitive** an individual's race/ethnic origin, marital status, age, religious/philosophical/political affiliations, health, education, genetic or sexual life, and government-issued identifiers, and gives biometric data special status. Setnayan processes the following sensitive categories, each on the noted basis:

Sensitive category	Where it appears	Basis	Safeguards
Religion / faith	Self-profile religion (ROPA 2); wedding ceremony rite and Islamic-rite fields (mahr, seating posture, wali/witness/imam roles) and Chinese/Tsinoy rite (ROPA 4); dependent's religion (ROPA 5)	§ 13(a) explicit consent (self / guardian), timestamped where captured at profile level	Optional; withdrawable; never sold or used for advertising; faith surfaced only to the couple's own event workspace
Marital / civil status	Self-profile civil_status (ROPA 2)	§ 13(a) explicit consent, timestamped	Optional, reference-only
Age / minors' data	A person -dependent's birth date — only kind=person , and only a child (<18) or elder (>50); pets/other excluded (ROPA 5); christening child birth date + gender ; birthday celebrant age (ROPA 4)	§ 13(a) guardian consent; § 12(b) contract	Minors' data arises only where the responsible adult enters a child — it is not the defining purpose of the dependents table; heightened-care handling
Health-adjacent	Guest dietary restrictions / meal preference (ROPA 13); gender-reveal expected due-date (ROPA 4)	§ 13(a) consent	Collected only where the event requires it; not used beyond the event
Gender / sex	Self-profile sex (ROPA 2); dependent / honoree sex (ROPA 4-5)	§ 13(a) consent, timestamped at profile level	Optional; reference-only

Biometric — facial geometry	Optional per-event photo-matching (ROPA 11)	§ 13(a) explicit opt-in consent, timestamped	Adults 18+; scoped to a single event, never reused across events ; consent withdrawal permanently deletes the vector + selfie; vector storage currently dormant (enrolment image-only until the model activates)
Government ID + sanctions/PEP screening	Vendor verification (ROPA 10)	§ 12(b)/(c)/(f)	Vendor business owners only; restricted-access; retained to the statutory floor then disposed

Users who provide none of the optional categories (religion, civil status, gender, biometric enrolment, dependents) supply no sensitive personal information beyond what a given event type strictly requires. The presence of these sensitive categories is a basis for **NPC registration** (§ 5 IRR registration triggers).

Note (2026-07-13): the public notice **already** carries an accurate opt-in **Biometric data (facial recognition)** section (explicit consent, adults 18+, per-event scope, withdrawal → permanent deletion) and a **Device identifier (fraud prevention)** section — the earlier "notice denies biometrics / omits the device identifier" concern came from a **stale local checkout**, not the deployed **origin/main**. Face-vector storage is currently **dormant** (enrolment image-only until the matching model activates), which the section's opt-in framing already accommodates.

6. Data Subject Rights (RA 10173 § 16)

Setnayan honors the rights to be **informed, access, object, rectify/correct, erase or block, data portability, and to lodge a complaint / claim damages**. Operationally:

- **Access + portability:** a self-service "download my data" export (iteration 0025) that includes the sensitive-personalization and family-graph fields.
- **Erasure/blocking:** soft-delete → hard-delete of account data, subject only to the legal-hold carve-out (§ 3). Withdrawing religion / civil status / gender / biometric / dependent consent deletes the corresponding data.
- **Objection/withdrawal:** analytics opt-out (cookie consent + profile toggle); face-recognition consent revocation (deletes the vector); marketing-preference controls.
- **Correction:** profile/settings self-edit.
- **Complaints:** routed to the DPO at dpo@setnayan.com; **15-business-day** response SLA; the data subject retains the right to complain to the NPC.

7. Subprocessors and Cross-Border Transfers (§ 21)

Setnayan uses the following subprocessors. Cross-border transfers rely on § 21 and each provider's adequacy/contractual commitments.

Subprocessor	Function	Location	Notes
--------------	----------	----------	-------

Supabase	Database + authentication	Singapore	Primary data store; RLS enforced
Vercel	Web application hosting	United States	
Cloudflare	CDN + R2 object storage (media)	APAC / PH-region buckets	
Resend	Transactional email	United States	
Sentry	Server-side error monitoring (stack traces only, no PII)	United States	
PostHog Cloud	Product analytics (cookie-consent opt-in; no personal identifiers)	United States	
Anthropic	AI features (deterministic-assist / optional AI)	United States	No training on user data
Persona	Vendor identity verification	United States	Automated verification staged ; vendor documents currently reviewed by the Setnayan admin team. No data flows to Persona until activation (disclosed before it begins)
Google LLC	Google Drive / YouTube (only when the user connects the optional integration)	United States	OAuth, opt-in; Google Limited Use commitment (no AI/ML training)

TikTok	Patiktok video publish (only when the user connects the optional integration)	United States / Singapore	OAuth, opt-in; scopes limited to profile + video upload/publish
Suno	AI music generation for Pakanta / rendered videos	United States	Owned-catalog generation; no personal data in prompts
Backblaze B2	Cold object storage — Papic compressed-gallery cold tier at scale	United States	Not yet active — flag-gated; engaged only once the aggregate cold pile reaches ~tens of TB

CSAM hash-matching provider (e.g. PhotoDNA / NCMEC)	Known-illegal-image hash matching for any open-crowd capture (corporate / tournament) — <i>restated 2026-07-20: the cancelled "Papic Lite" product is no longer the trigger; the duty travels with open-crowd ingest</i> (Papic Compliance Delta 2026-07-20.md §3.2)	United States	Not yet engaged — and no open-crowd capture is offered in V1; mandatory-rep duty to be reviewed by counsel before any such capture ships
---	--	---------------	---

Cross-border destinations disclosed: Singapore (Supabase), United States (Vercel, Cloudflare account plane, Resend, Sentry, PostHog, Anthropic, Persona, Google, Suno), United States/Singapore (TikTok). Media objects reside in Cloudflare's PH-region R2 buckets.

8. Organizational, Physical, and Technical Security Measures

- **Access control:** database Row-Level Security (RLS) on all tables (enabled at table creation); role-scoped access; two-admin approval gates for major administrative decisions.
- **Cryptographic controls:** passwords hashed; the device identifier is a **one-way salted hash** (raw value never stored); OAuth grants encrypted at rest; transport over TLS.
- **Data minimization:** analytics carry no personal identifiers; error logs exclude message bodies, payment details, and guest data; IP truncated to 3 octets for QR-scan events. *(Minimization item: some aggregate dashboard views load fuller records than they display — a tightening pass is tracked in §11.)*
- **Content safety:** an NSFW filter is on by default and cannot be disabled.
- **Confidentiality by design:** vendor identity masking (a vendor sees only the couple's event display name + date, never their email or personal name unless shared).
- **Residency:** database in Singapore; media in PH-region object-storage buckets.
- **Breach response:** the DPO coordinates assessment and any NPC + data-subject notification within the periods required by the NPC's breach rules.

8a. Retention governance

Retention is bounded on both ends: **RA 10173 storage-limitation** as the maximum, and **statutory floors** as the minimum for financial and contractual records (BIR RR 17-2013 = 10 years for payments/Official Receipts; Civil Code Art. 1144 for contracts). Per-class periods are maintained in the **Data Retention Schedule (2026-07-11)**; periods marked (*counsel*) await external ratification.

■ **CORRECTION PENDING (2026-07-20) — do not lodge this paragraph as written.** Two of its numbers are contradicted by the shipped system: the **6 months** below is **90 days** in code (DEFAULT_FULL_RES_RETENTION_DAYS = 90, apps/web/lib/papic-fullres-drop-core.ts:10 @ origin/main 5b72d625d, and the drop sweep is **ON by default**), and **"indefinitely"** for the compressed copy contradicts the **5-year** media period in Data_Retention_Schedule_2026-07-11.md row 2 and the storage-limitation principle at that file's :15. Operationally "indefinitely" is currently accurate only because **no media purge exists** (R2 lifecycle NOT configured). Two clean resolutions with their consequences — and the note that PAPIC_FULLRES_RETENTION_DAYS=180 fixes it without a code change — are in [Papic Compliance Delta 2026-07-20.md](#) §1. **This paragraph blocks all retention marketing copy until resolved.**

Papic media lifecycle (2026-07-17). Captured photos and 5-second clips are kept at full resolution for **6 months** (for the couple to download or sync to their own Google Drive). After the window the full-res original is **dropped from Setnayan storage** unless the couple has synced it to their Drive; a **compressed web copy** (photos + compressed clip copies) is retained on the couple's gallery indefinitely as the serving copy — so no media type carries an unbounded full-resolution tail. Optional facial-geometry vectors (ROPA 11) auto-expire per event at ~5 years; the account-level face profile is governed by account deletion, not this per-event clock. Papic Lite (ROPA 20) is photos-only and biometric-free.

9. Compliance Statement

Setnayan processes personal data under RA 10173 on the bases recorded in § 3, with retention bounded on both ends (RA 10173 storage-limitation as the maximum; BIR/Civil Code statutory floors as the minimum for financial and contractual records). Data subject rights are implemented and honored; sensitive personal information (religion, civil status, gender, minors' data, health-adjacent data, biometric, and vendor government-ID) is processed only on the bases in § 5; the fraud-prevention device identifier is minimized, pseudonymized, and DPO-gated (currently dormant). The DPO is the proprietor and is the point of contact for the NPC and for data subjects.

Prepared by (DPO): _____ (Indalecio S. Casasola II) — dpo@setnayan.com

Date: 2026-07-13

10. Appendix — companion documents

- [Privacy_Reconciliation_Home_and_Data_Flows_2026-07-13.md](#) — the reconciliation that drove the v2.0 expansion.
- [Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md](#) — DPO one-pager for the device-fingerprint processing.
- [Data_Retention_Schedule_2026-07-11.md](#) — full per-class retention schedule + [PENDING COUNSEL] items.
- [Papic_Compliance_Delta_2026-07-20.md](#) — ■ **the three open defects in THIS draft (retention 90 d vs 6 mo · missing media ROPA row · the false "Papic Lite is built" claim) plus the RSVP-consent question for DPO ruling. Read before lodging.**
- [NPC_Compliance/](#) pack — the deeper filing set (Privacy Manual, full RoPA, DPO Designation + NPCRS data sheet, Breach Policy, DPIA register, Face-Vector DPIA, Anti-Fraud DPIA). This dossier is the executive summary over that pack; the two must be kept consistent.
- [01_Contracts/Setnayan_Privacy_and_Security_Policy.md](#) — the binding public policy (to be reconciled per §11).
- Public privacy notice — setnayan.com/privacy.
- [\[\[dpo-designation-owner\]\]](#) — DPO designation record.

11. Open items before filing (owner / DPO / external counsel)

Blocking on external counsel (this dossier is not legal advice):

1. External counsel review of this dossier + the retention periods marked (*counsel*), with specific attention to the **§ 3(I) / minors' data** cluster (dependents, christening child data, godparent third-party notification) and the vendor **AMLC/PEP + government-ID** screening basis.
2. Confirmation of the **NPC registration threshold** applicable to the business.

Owner / DPO actions (documentation + product):

3. **Public privacy notice — DONE (app PR #3215, 2026-07-13):** added the **faith / family / honoree / e-gift** disclosures + Anthropic/Suno subprocessors; the opt-in **biometric** and **device-identifier** sections were already present. Remaining notice work is wording refinement by counsel, not a coverage gap.
4. **Reconcile the older corpus documents** to the values in §1: align `iscasasolaii@gmail.com` → `dpo@setnayan.com` and the 7-business-day SLA → 15 in the binding Privacy & Security Policy; add the **10-year floor** and the **vendor-verification retention class** to that policy's §4 retention table; add **Persona, TikTok, Suno** to its §10 subprocessor table.
5. **Device-fingerprint status:** correct the draft Anti-Fraud Policy amendment's "active since 2026-07-07" language to match the confirmed **flag-OFF** state, and gate the notice disclosure to activation.
6. **Known product remediation** (tracked, not blocking this draft): account hard-delete does not yet purge chat-message PII (Retention Schedule §4); the `events.signature_details` honoree fields (christening child data, gender-reveal due-date) collect sensitive data without a per-field consent timestamp — **documented as-is per owner direction**, flagged here for a future consent-instrumentation pass; and the dashboard data-minimization tightening in §8.

Papic v3 (added 2026-07-17):

7. ■ **WITHDRAWN 2026-07-20 — this item states a falsehood about our own system.** The pool described below was **never implemented** (no flag, table, route or migration; zero code matches) and the product was **cancelled 2026-07-20** before any processing occurred. Replacement wording is drafted at [Papic_Compliance_Delta_2026-07-20.md](#) §3.2; the bystander / minors-in-crowd / CSAM questions are **deferred, not closed** — they attach to any future open-crowd event type. Original text for lineage: *Papic Lite public-launch gate (counsel + DPO) — blocking Lite only*. The open, public-QR photo pool (ROPA 20) is built but flag-OFF. Enabling it requires sign-off on: bystander/subject consent at QR-join; the **public takedown/complaint mechanism** that serves the erasure right absent face-search (Lite is biometric-free); a minors-in-crowd notice (concerts/reunions/tournaments); and a **CSAM known-hash matcher + mandatory-reporting** review before an anonymous public upload endpoint goes live. Wedding Papic is unaffected.
8. **Face-vector 5-year expiry (DPO).** Confirm the expiry anchor (event date vs enrolment) and whether the enrolment **selfie** biometric asset is purged at expiry or retained (default proposed: null the vector, retain the photo). Add the sweep to the Data Retention Schedule + Face-Vector DPIA.
9. ■ **Security-statement reconciliation (before filing).** §8 states "OAuth grants encrypted at rest," but the Papic build review found the Google-Drive `oauth_grants.refresh_token / access_token` stored **in plaintext** today. Either implement application-layer encryption to make the statement true, or correct §8 — a submission must not overstate a technical control.

Filing note. This is a complete, DPO-prepared submission draft: the ROPA, PIA, sensitive-PI declaration, subprocessor list, security measures, and data-subject-rights implementation are all present and reconciled to the as-built platform as of 2026-07-13. It is **ready for external counsel review**, which — together with items 1-2 above — is the final gate before lodging with the NPC.

Setnayan — NPC / RA 10173 Compliance Documentation Pack

Date assembled: 2026-07-05

PIC: SETNAYAN SOFTWARE DEVELOPMENT SERVICE (sole proprietorship of Indalecio S. Casasola II · DTI Business Name No. 8297508)

DPO: Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com

Status: DRAFT — filing-ready, NOT yet filed. Every document is built to a compliant RA 10173 / NPC baseline ahead of counsel. For DPO (the owner) + PH counsel finalization, then filing/keepsake. **Not a substitute for legal review.**

What this pack is

The formal records a Personal Information Controller keeps on file and uses to register with the **National Privacy Commission (NPC)** under the Data Privacy Act of 2012 (RA 10173). This is your **keepsake + filing set**.

#	Document	Purpose
01	Privacy Manual	The flagship RA 10173 governance document (present to NPC on request) — 12 sections: scope, definitions, governance + security, principles, lifecycle, the 8 data-subject rights, consent, sub-processors/cross-border, breach, DPIA, complaints, versioning
02	Records of Processing Activities (RoPA)	Data-processing-systems inventory (11 systems) + the NPC-registration threshold analysis
03	DPO Designation + NPC Registration data sheet	The owner's formal DPO appointment record (PIC = DPO) + the field-by-field data to complete NPC registration
04	Data Breach Management Policy	Per NPC Circular 16-03 — 72-hour rule, response team, notification, breach register
05	DPIA Register + Person-Graph DPIA	Impact-assessment register + one completed DPIA (person graph); flags what still needs one

All five carry the same DRAFT header and the "compliant baseline, not a substitute for legal review" footer.

How to actually file (this pack is the content, not the filing)

1. **Fill in the [TO CONFIRM] facts** below (one pass supplies them across all docs).
2. **You review & adopt as both PIC and DPO** — sign the designation + manual; set the effectivity dates. (PH counsel to review before publishing any policy text.)
3. **Register with the NPC online** via the **NPC Registration System (NPCRS)** at register.privacy.gov.ph — this registers the PIC, the DPO's contact details, and the Data Processing System(s). *(This online filing is the*

DPO/owner's action — I can't file on your behalf.)

4. **Keep the adopted set as your accountability records** (the "keepsake"); update on the review cadence in the Manual.

Master list — facts you must supply ([TO CONFIRM], 98 occurrences → these distinct items)

Business identity

- Registered / principal place of business address
- BIR TIN / Form 2303 number
- Existing NPC PIC + DPO registration number (after you file)

Scale (required registration fields)

- Total headcount / employees (and how many have access to personal data)
- Number of data subjects — customers, vendors, guests (approx.)
- Number of data subjects whose **sensitive** personal info you hold

DPO (the owner) details

- Contact email · mobile/landline · designation effectivity date · **the PIC = DPO conflict-of-interest note** (the proprietor also serves as DPO — record a short independence rationale; NPC generally prefers DPO autonomy from the controller, but this is commonly accepted for a 2-person sole proprietorship)

Data Breach Response Team

- Names for: Technical/Engineering Lead · Security/Ops Coordinator · Comms/Legal liaison (external PH counsel) · the 24/7 escalation phones + email · the DPO breach hotline number

Sub-processors (jurisdiction + executed DPA on file)

- Vercel · Resend (+ SendGrid fallback) · Suno · PostHog (host + opt-out) · the face-matching engine host/location
- ■ **Suno is not in the Privacy Policy's sub-processor table** — add it (or confirm it processes no personal data)

Processing specifics

- Exact RSVP special-data fields (dietary/health/religious?) — decides whether the guest system is a formal sensitive-PII system
- Automated-decision inventory: the Anti-Fraud auto-suspend (DPS-12 / R-08) **is** a solely-automated decision with a significant effect (reversible); confirm the RA 10173 §16(c)/§34 contest/appeal path is documented
- Maya Business (V1.5 payment gateway) contract status
- Personnel controls: signed NDAs on file · privacy-training cadence · device/endpoint policy
- DPIA review + sign-off dates

Two things flagged for your attention

1. **Biometric face vectors likely need their own dedicated full DPIA.** The person-graph DPIA (doc 05, Part 2) is complete, but face-vector processing is sensitive (biometric) and is flagged as needing a *separate* HIGH-risk DPIA — not folded into the person-graph one. Worth doing before scaling that feature.
2. **Publish order:** the **Privacy Policy amendment** (person-graph, in 01_Contracts/) and doc 05's person-graph DPIA should be **finalized with the DPO (owner) + PH counsel before the amendment goes public** — the features are live behind flags, but the public policy text publishes on sign-off.

Companion documents (outside this folder)

- 01_Contracts/Setnayan_Privacy_and_Security_Policy.md — the binding public policy (now with the 2026-07-05 person-graph amendment)

- 03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md — consent notices + the source person-graph DPIA
- 03_Strategy/Phase2_Counsel_Review_Brief_2026-07-05.md + Phase3_Minors_and_Legacy_Counsel_Brief_2026-07-05.md — the two counsel briefs (for the DPO/owner + PH counsel)

Prepared to a compliant baseline ahead of counsel per the standing compliance-by-default rule. Finalize with Indalecio Sacdalan Casasola II (DPO) + PH counsel before filing/publishing.

Setnayan Privacy Manual

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted.

Date drafted: **2026-07-05**

Document ID: `NPC_Compliance/01_Privacy_Manual_DRAFT_2026-07-05.md`

Governing law: Republic Act No. 10173 (Data Privacy Act of 2012), its Implementing Rules and Regulations (IRR), and issuances of the National Privacy Commission (NPC).

This Privacy Manual is the flagship governance document of the Personal Information Controller. It states how the organization collects, uses, stores, discloses, and disposes of personal data; how it upholds the rights of data subjects; and how it manages security, breaches, and cross-border transfers. It is intended to be kept on file and presented to the NPC on request.

1. Introduction, Purpose & Scope

1.1 The Personal Information Controller (PIC)

Field	Value
Legal entity	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — a sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	No. 8297508 (national scope; valid 25 Jun 2026 – 25 Jun 2031)
Brand	Setnayan
Domains / platform	<code>setnayan.com</code> · <code>setnayan.ph</code>
Nature of business	Philippines-first life-events (weddings-first) planning platform serving three roles — customers (couples/organizers), vendors, and guests
Registered address / principal place of business	[TO CONFIRM]
Number of employees / personnel with access to personal data	[TO CONFIRM]
Approximate number of data subjects	[TO CONFIRM]
NPC registration number (PIC/DPO registration)	[TO CONFIRM]

1.2 Purpose

This Manual:

- Documents the PIC's personal data processing activities and the safeguards applied to them.
- Serves as the reference for all personnel who process personal data on the PIC's behalf.
- Demonstrates the PIC's accountability and compliance posture to the NPC, to data subjects, and to partners.
- Operationalizes the binding **Setnayan Privacy & Security Policy** (`01_Contracts/Setnayan_Privacy_and_Security_Policy.md`), which every account holder accepts at registration.

1.3 Scope

This Manual applies to **all personal data** processed by the PIC across all systems, personnel, contractors, and sub-processors, in every format (electronic and, where applicable, physical). It covers the personal data of **customers, vendors, and guests**, and the internal personnel data the PIC processes as an employer/engager [TO CONFIRM headcount].

1.4 Commitment to RA 10173

The PIC commits to upholding the three data privacy principles — **transparency, legitimate purpose, and proportionality** — and to protecting the rights of every data subject. The platform is built on a **privacy-by-design + compliance-by-default** posture: privacy safeguards are engineered into the systems (row-level access control, encryption, per-event scoping) rather than bolted on. The organization's person-graph features are **adults-only**; processing of minors' data and legacy/post-mortem data is a future, counsel-first phase and is **not undertaken now**.

2. Definitions

Terms used in this Manual carry the meanings assigned by RA 10173 and its IRR:

Term	Meaning
Personal Information (PI)	Any information from which the identity of an individual is apparent or can reasonably and directly be ascertained, or when put together with other information would directly and certainly identify an individual.
Sensitive Personal Information (SPI)	PI about an individual's race, ethnic origin, marital status, age, colour, religious/philosophical/political affiliations; health, education, genetic or sexual life; any proceeding for any offence; government-issued identifiers (SSS, TIN, etc.); and information specifically established by law as classified.
Privileged Information	Any and all forms of data which, under the Rules of Court and other pertinent laws, constitute privileged communication.
Personal Information Controller (PIC)	A person or organization who controls the collection, holding, processing, or use of personal information — here, SETNAYAN SOFTWARE DEVELOPMENT SERVICE.
Personal Information Processor (PIP)	Any natural or juridical person to whom a PIC may outsource or instruct the processing of personal data (the PIC's sub-processors — see § 8).
Data Subject	The individual whose personal information is processed — Setnayan's customers, vendors, and guests.
Processing	Any operation performed upon personal data — collection, recording, organization, storage, updating, retrieval, consultation, use, consolidation, blocking, erasure, or destruction.
Consent	Any freely given, specific, informed indication of will by which the data subject agrees to the processing of personal data about them.
Data Protection Officer (DPO)	The individual designated by the PIC to be accountable for compliance with RA 10173.

Personal Data Breach	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data.
-----------------------------	--

3. Governance & Organizational Structure

3.1 Data Protection Officer (DPO)

Field	Value
Designated DPO	Indalecio Sacdalan Casasola II
DPO contact	iscasasolaii@gmail.com
NPC DPO registration	[TO CONFIRM]

The DPO is the organization's accountable officer for data privacy and the single point of contact for data subjects and for the NPC. The DPO's responsibilities include:

- Monitoring and ensuring the PIC's compliance with RA 10173, its IRR, NPC issuances, and this Manual.
- Serving as the contact point for data subject requests and complaints (access, rectification, erasure, objection, portability, and breach inquiries).
- Overseeing the conduct of Data Privacy Impact Assessments (DPIAs — see § 10) and maintaining the DPIA register.
- Leading the security incident and breach response process (see § 9), including NPC and data-subject notification.
- Cultivating a privacy-aware culture through personnel training and periodic review of policies.
- Reviewing and advising on sub-processor engagements and cross-border transfers.

3.2 Security Measures — Overview

The PIC maintains organizational, physical, and technical security measures proportionate to the nature of the personal data processed and the risks involved. The measures below summarize the controls already in place per the binding Privacy & Security Policy.

3.2.1 Organizational measures

- **Binding policy acceptance.** Every customer, vendor, and guest accepts the Privacy & Security Policy at registration; acceptance is logged with timestamp, IP, and user-agent in a `policy_acceptances` record per user.
- **Role-based responsibility.** Internal (admin) access is gated to granular roles; each role can only reach the surfaces it is permitted.
- **Two-admin approval** for high-impact actions — role provisioning, brand-configuration changes, refunds above ₱10,000, and unlimited-use grants above ₱10,000 retail value.
- **Confidentiality obligations** on personnel and contractors `[TO CONFIRM: signed NDAs / conduct policy on file]`.
- **Privacy training** for personnel who process personal data `[TO CONFIRM: cadence]`.

3.2.2 Physical measures

- **No self-hosted data centre.** The PIC does not operate physical servers; personal data resides with managed cloud processors (Supabase, Cloudflare) under their physical-security controls and data-processing agreements.
- Access to workstations and administrative credentials is restricted to authorized personnel [TO CONFIRM: device/endpoint policy].

3.2.3 Technical measures

Control	Implementation
Access control (deny-by-default)	Row-Level Security (RLS) on the Postgres database — every query is gated so no client can read another user's row. Deny-by-default is the baseline; access is granted only by explicit policy.
Encryption in transit	TLS 1.3 on all external connections and WebSocket channels; HSTS enabled in production; mixed content blocked.
Encryption at rest	AES-256 on the database and object storage; keys managed by the cloud providers' key-management services. Face vectors stored in a per-event encrypted vector index.
Authentication	Email + password (bcrypt-hashed, never plaintext), or mobile + OTP, or Google/Apple SSO; TOTP two-factor available for customers/vendors and mandatory for all admin roles .
Session management	30-day inactivity expiry; refresh tokens stored httpOnly; single sign-out across all devices.
Short-lived media access	Object storage is private; access is via short-lived signed URLs (5 minutes for sensitive media). No public reads.
Application hardening	Input validation at every entry point; parameterized queries (no SQL injection); output escaping + CSP (no XSS); CSRF tokens on state-changing requests; rate limiting on auth endpoints.
Audit logs	Every admin action is logged append-only (no UPDATE permission) with timestamp, actor, action type, target entity, before/after state, and rationale.
Backups	Daily encrypted database backups retained 30 days.

4. Data Processing Principles Applied

The PIC applies the three RA 10173 principles to every processing activity:

4.1 Transparency

Data subjects are informed of the nature, purpose, and extent of processing before or at collection. Mechanisms:

- Registration-time acceptance of the Privacy & Security Policy (logged per user).
- A published privacy notice on setnayan.com/privacy and a changelog at setnayan.com/privacy/changeLog; material changes carry 30 days' notice and a re-consent prompt where processing changes.
- The DPO's contact (iscasasolai@gmail.com) is published as the channel for questions and rights requests.

4.2 Legitimate Purpose

Processing is limited to declared, specified, and legitimate purposes and is never incompatible with them. Concrete examples:

- **Service delivery** — providing the planning tools, gallery, RSVP, and vendor-matching a customer contracts for (basis: performance of contract / legitimate interest).
- **Payments** — apply-then-pay reconciliation using **reference data only**; no card, CVV, or full bank-account numbers are stored (basis: performance of contract).
- **Vendor verification** — identity, business-registration, and sanctions screening at onboarding (bases: consent, legitimate interest, compliance with the PH Anti-Money Laundering Act).
- **Face auto-tagging** — matching a guest to their own photos, per-event only, on explicit/implied consent (basis: consent).

4.3 Proportionality

Only data adequate, relevant, and necessary to the declared purpose is processed:

- **Payment data minimization** — reference and receipt data only, never full credentials.
- **Per-event face scoping** — face vectors are generated and used **per event only, never reused across weddings**, and are deleted with the event data. There is **no cross-event face recognition**.
- **Person-graph minimization** — connections require **mutual confirmation**; cross-person visibility is **name-only**; extended relationships are **derived, never stored**; trusted-circle signals are **aggregated/computed** (≥ 5 minimum), **never per-person records**.

5. Data Lifecycle: Collection → Use → Storage → Disclosure → Disposal

5.1 Collection

Personal data collected, by role:

Role	Categories collected
Customer (couple/organizer)	Full name, mobile, email, optional profile photo; event details (date, venue, target pax, role); payment reference/receipt data (no full credentials); in-app behavioral data; uploaded content (photos, invitation customizations); chat messages with vendors/coordinators.
Vendor	Business + identity documents (DTI Business Name Certificate, BIR Form 2303, Mayor's Permit, government ID, bank-account proof, portfolio, client references, live selfie + liveness); service profile; payout account and transaction history; behavioral data; chat messages. Includes SPI (government-issued identifiers).
Guest	Full name, mobile, email, optional profile photo; event linkage and role; RSVP status and table assignment; captured/tagged photos and clips; behavioral data (reels built, reshares).
Face vectors (special category)	Per-event face vectors derived from RSVP profile photo + optional pre-event upload + on-the-day check-in kiosk, used only for auto-tagging within that one event.

5.2 Use

Primary uses: providing contracted services, vendor matching, payment processing, per-event photo auto-tagging, event/payment notifications, and aggregated platform analytics. Secondary uses (anonymized aggregate improvement/ML, marketing samples, promotional communications) require **separate, revocable consent**. Personal data is **never sold**, never used for external targeted advertising, and never shared with government except as required by Philippine law (subpoena/court order).

5.3 Storage, Residency & Retention

System	Location	Content
Database (Postgres)	Supabase — Singapore	PII + transactional data, RLS-gated, AES-256 at rest
Object storage	Cloudflare R2 — APAC region	Photos/videos, per-event encrypted face-vector index, vendor verification documents; private + signed-URL access
Email	Resend	Transactional/notification email delivery

Representative retention windows (full table in the Privacy & Security Policy § 4):

Data type	Retention	Deletion trigger
Customer/vendor account profile	Active	Account deletion + 30-day grace then purge
Customer event data	5 years post-event	Auto-purge at T+5 years (or earlier on request)
Photo/video originals	90 days hot → 5 years cold	5-year hard limit
Face vectors	Per-event lifetime + 5 years	Auto-purge with event data; guest "delete my face data" revokes within the refresh cycle
Vendor verification audit trail / permits	90 days hot → 7 years cold	BIR § 235 + AMLC AML/CTF retention
Chat messages / audit logs	5 years	Aligned with event / tax-legal retention
Anonymized aggregate data	Indefinite (no PII)	Not auto-purged

5.4 Disclosure / Sharing

Disclosure is limited to the sub-processors in § 8, each engaged under a data-processing agreement and used only for the declared purpose. Internal (Setnayan Team) access to event media is read-only, case-scoped to mediation, and never bulk-exported.

5.5 Disposal

Disposal occurs by automated purge at the retention boundary or on a validated deletion request. Account deletion cascades to profile, event memberships, face vectors, individual photos of the subject (subject to event-organizer consent for shared galleries), and chat history — **except** records the PIC must retain for PH tax/legal compliance (e.g., BIR vendor records, payment receipts), which are retained for their statutory period and then destroyed.

6. Data Subject Rights

Every data subject has the following rights under RA 10173. All are exercised by contacting iscasasolaii@gmail.com (and, for several, via in-app settings surfaces).

#	Right	How to exercise / PIC response
1	Right to be informed	Via this Manual, the published privacy notice, and registration-time disclosures.
2	Right to access	Request a copy of personal data held, via iscasasolaii@gmail.com . Response: within 7 business days for non-urgent requests.
3	Right to object	Opt out of specific data uses (e.g., marketing samples, promotional email) via settings or iscasasolaii@gmail.com .
4	Right to rectification	Edit profile in-app; request corrections via iscasasolaii@gmail.com .
5	Right to erasure or blocking	Delete account via the in-app "Delete my account" surface; confirmed within 30 days ; cascade per § 5.5, with statutory-retention exceptions.
6	Right to damages	File a complaint with the NPC for violations; the PIC cooperates with any NPC proceeding.
7	Right to data portability	Export event data, photos, and chat history in a machine-readable format, via iscasasolaii@gmail.com or in-app export.
8	Right to be notified	Notification of any breach affecting the subject's data, per § 9.

Person-graph specific rights: a data subject may decline connection requests, remove confirmed connections, hide individual life-story items per-person (without affecting the host's gallery), and opt out of an event's story entirely; deletion cascades to their connections and story-item references.

7. Consent Management

- **Registration consent.** Acceptance of the Privacy & Security Policy is captured and logged (timestamp + IP + user-agent) at account creation.
- **Face detection.** Guests consent to face auto-tagging by uploading an RSVP profile photo for that purpose (implied consent) and can withdraw at any time via a "Photo Consent" toggle; withdrawal triggers face-blur in captures and revocation of face data. Face processing is **per-event only**.
- **Vendor verification consent.** Vendors give explicit, itemized consent at registration for DTI lookup, third-party ID/liveness verification, portfolio reverse-image search, reference calls, and AMLC sanctions screening.
- **Marketing samples.** Use of a customer's renders/captures as marketing samples requires a **separate written opt-in**, revocable at any time; existing materials are removed within 90 days of revocation.

- **Person graph.** Connections require **mutual confirmation** (no one-sided edges); life-story items rely on existing event photo-consent and are individually hide-able/opt-out-able; trusted-circle recommendations are aggregate-only.
- **Withdrawal.** Consent may be withdrawn at any time through settings or iscasasolaii@gmail.com, without affecting the lawfulness of prior processing.
- **Material changes** to processing carry 30 days' advance notice and a re-consent prompt at next login where the change affects data use.

8. Data Sharing, Sub-Processors (PIPs) & Cross-Border Transfers

8.1 Hosting & cross-border disclosure

The PIC's primary infrastructure is hosted **outside the Philippines**: the database in **Singapore** (Supabase) and object storage in the **APAC region** (Cloudflare R2). Routine application operations therefore involve **cross-border processing**. All such transfers are encrypted in transit (TLS 1.3), governed by the providers' data-processing agreements, and remain subject to NPC oversight; the PIC remains accountable for personal data transferred to any processor.

8.2 Sub-processors (Personal Information Processors)

Sub-processor	Jurisdiction	Data shared	Purpose
Supabase	Singapore	PII + transactional data	Managed database hosting
Cloudflare (R2)	APAC region	Media, face-vector index, vendor documents	Object storage / CDN
Resend	[TO CONFIRM jurisdiction]	Recipient email + message content	Transactional email delivery
Persona / Veriff / Onfido	US	Vendor government-ID image + selfie + liveness	Vendor identity verification
AMLC API / ComplyAdvantage	PH / UK	Vendor business + owner name	Sanctions / PEP screening (PH AMLA compliance)
DTI Database	PH	Vendor DTI certificate number	Business-registration validation
Anthropic / OpenAI	US	Vendor contract text (AI features only)	Contract analysis and AI features; the specific model is not named to users . Configured for zero-retention where available.
Suno	[TO CONFIRM jurisdiction]	No personal data	Music generation (owned AI catalogue)

All non-ASEAN sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent enforceable data-processing agreements. AI/verification/screening calls are batch/inference-only with no ongoing storage at the sub-processor where so configured. [TO CONFIRM: executed DPA on file for each active processor.]

9. Security Incident & Personal Data Breach Management

The PIC maintains a documented incident-response and breach-management process. Summary posture:

- **Detection & assessment.** Incidents are assessed by the DPO and response team to determine whether a **personal data breach** has occurred and its severity.
- **NPC notification.** Where the breach is notifiable, the NPC is notified **within 72 hours** of knowledge/confirmation, consistent with RA 10173 and NPC Circular 16-03.
- **Data-subject notification.** Affected data subjects are notified **within 72 hours** (in-app + email) of what data was involved, when, remedial actions taken, and recommended protective steps.
- **Public disclosure.** A breach summary is posted on setnayan.com/security within 7 days where appropriate.
- **DPO channel.** Breach inquiries go to iscasasolaii@gmail.com; a hotline is used for high-severity incidents.
- **Records.** All incidents and responses are documented for the mandatory breach report and NPC review.

The full procedure — response team, severity matrix, containment/eradication/recovery steps, notification templates, and the breach register — is maintained in the **Data Breach Management Policy**:
[NPC_Compliance/04_Data_Breach_Management_Policy_DRAFT_2026-07-05.md](#).

10. Data Privacy Impact Assessments (DPIA)

The PIC conducts a **DPIA** before undertaking any processing that is likely to pose a risk to the rights and freedoms of data subjects — in particular new features involving sensitive or high-volume personal data (e.g., face vectors, the person graph, vendor identity verification, and any future minors/legacy processing). Each DPIA identifies data flows, risks, and mitigations, and is reviewed by the DPO before the processing goes live.

The DPIA methodology and the register of completed/pending assessments are maintained in:
[NPC_Compliance/05_DPIA_Register_DRAFT_2026-07-05.md](#).

Minors' data and legacy/post-mortem processing are **not undertaken now**; when contemplated, each will be **counsel-first** and gated on a dedicated DPIA and guardian-consent/post-mortem mechanics.

11. Inquiries, Complaints & NPC Contact

- **Data subject inquiries and complaints** are directed to the DPO at iscasasolaii@gmail.com. The DPO acknowledges and responds within the timelines in § 6, coordinates rectification/erasure/objection, and maintains a record of complaints and their resolution.
- **Escalation to the NPC.** A data subject who is not satisfied may lodge a complaint with the **National Privacy Commission**:

National Privacy Commission
5th Floor, Philippine International Convention Center (PICC) Complex, Vicente Sotto St., Pasay City, Metro Manila 1307
Email: info@privacy.gov.ph · Website: privacy.gov.ph
[TO CONFIRM current NPC address/contact at time of filing]

12. Review, Version Control & Effectivity

- **Ownership.** This Manual is owned by the DPO (Indalecio Sacdalan Casasola II) and approved by the PIC (Indalecio Sacdalan Casasola II).

- **Review cadence.** Reviewed at least **annually**, and additionally upon any material change to systems, sub-processors, or applicable law/NPC issuances.
- **Change control.** Material changes to processing are communicated to data subjects per § 7 and § 11 of the Privacy & Security Policy (30 days' notice; re-consent where required; public changelog).
- **Effectivity.** This document is a **DRAFT** and takes effect only upon adoption and sign-off by the DPO/counsel and, where required, NPC filing.

Version	Date	Author	Status
0.1 (DRAFT)	2026-07-05	Prepared for DPO/counsel review	Not yet adopted
Adopted	[TO CONFIRM]	Indalecio Sacdalan Casasola II (DPO)	[TO CONFIRM]

Approval blocks (to be completed on adoption):

- PIC / Owner: Indalecio Sacdalan Casasola II — Signature: __ Date: ____
- DPO: Indalecio Sacdalan Casasola II — Signature: __ Date: ____

Footnote. This document was drafted to a compliant RA 10173 baseline **ahead of counsel** to accelerate finalization. It is **not a substitute for legal review**. The designated DPO (Indalecio Sacdalan Casasola II) + PH counsel must verify every [TO CONFIRM] fact, confirm alignment with the current NPC issuances, and formally adopt this Manual before it is relied upon or filed.

Setnayan — Records of Processing Activities (RoPA) / Data Inventory

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from 01_Contracts/Setnayan_Privacy_and_Security_Policy.md (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and 03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md. Facts not established in those sources are marked [TO CONFIRM] — none invented.

0. Controller & governance identification

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031
Brand / trade name	Setnayan
Public domains	setnayan.com · setnayan.ph
Registered business address	[TO CONFIRM]
Total headcount / employees	[TO CONFIRM]
NPC registration number (if already registered)	[TO CONFIRM]
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com (registered with the NPC per policy §9)
DPO response SLA	7 business days (non-urgent); immediate for breach notifications
Breach notification	NPC + affected users within 72 hours of confirmation (policy §8)
Estimated data-subject counts (customers / vendors / guests)	[TO CONFIRM]

Shared infrastructure (applies across DPS's unless a row narrows it)

Layer	Provider	Location	Role
Web / application hosting	Vercel	[TO CONFIRM] (edge)	Processor
Primary database (PII + transactional)	Supabase / Postgres	Singapore	Processor · AES-256 at rest · RLS

Media (photos / video / face vectors)	Cloudflare R2	APAC / PH region	Processor · signed-URL access only
Transactional email	Resend	[TO CONFIRM] (US-based likely)	Processor
Vendor ID verification	Persona / Veriff / Onfido	US	Processor (batch-call, no ongoing storage)
AI text/contract analysis	Anthropic (Claude) · OpenAI (V1.5 fallback)	US	Processor · zero-retention API mode (Anthropic)
Music generation	Suno	[TO CONFIRM]	Processor — no PII processed

Cross-border baseline: routine operation crosses the SG↔PH border; encrypted in transit (TLS 1.3), governed by Cloudflare's and Supabase's PH-compliant DPAs, subject to NPC oversight (policy §10). US sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent (policy §10).

1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

DPS-01 · Customer / Couple Account & Event Planning

Field	Detail
Purpose	Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services
Legal basis	Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)
Data subjects	Customers (couples / organizers)
Personal data categories	Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations)
SPI?	N (no SPI in the core account record)
Recipients / sub-processors	Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only
Cross-border transfer	SG (Supabase); APAC/PH (R2)
Retention	Account profile: active + 30-day grace on deletion, then purge. Event data: 5 years post-event, auto-purge T+5y; earlier on request (policy §4)

Security measures	AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media
Risk level	Medium

DPS-02 · Vendor Account, Profile & Verification

Field	Detail
Purpose	Vendor onboarding, business profile, and the 12-document identity/business verification checklist (policy §3.4)
Legal basis	Contract (§12(b)); Legitimate interest (§12(f)) — DTI lookup, portfolio reverse-image, reference calls; Legal obligation (§13(f) / §12(c)) — AMLC sanctions/PEP screening per PH AMLA; Consent captured at registration
Data subjects	Vendors (business owners / primary representatives)
Personal data categories	Business identity (DTI Business Name Cert, BIR Form 2303, Mayor's Permit, business address, name+slug); service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion)
SPI?	Y — government-issued ID of the primary representative (RA 10173 §3(l) SPI); selfie + ID liveness video (biometric-adjacent). DTI/BIR/tax documents are legally-mandated records
Recipients / sub-processors	Persona / Veriff / Onfido (ID + liveness); AMLC API / ComplyAdvantage (sanctions/PEP); DTI Database (BN validation); Supabase; Cloudflare R2 bucket <code>setnayan-vendor-verification</code> (Verification Handler role only)
Cross-border transfer	US (Persona/Veriff/Onfido); UK (ComplyAdvantage); PH (AMLC, DTI); SG (Supabase); APAC/PH (R2)
Retention	Raw uploads (ID, selfie+liveness, bank micro-deposit, portfolio): 90 days hot, purged after approve/reject unless audit hold. Verification audit trail (Persona/AMLC results + admin rationale): 90 days hot + 7 years cold (BIR §235 + AMLC AML/CTF). DTI/BIR 2303/Mayor's Permit: 90 days hot + 7 years cold . Transaction history: 5 years (policy §4)
Security measures	Extra-restricted R2 bucket (single admin role); batch-call verification (no ongoing sub-processor storage); AES-256; RLS; audit log on all admin decisions
Risk level	High (SPI: gov ID + biometric liveness)

DPS-03 · Guest List & RSVP

Field	Detail
Purpose	Manage the couple's guest list, RSVP status, roles, table assignment, and special requests

Legal basis	Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)
Data subjects	Guests
Personal data categories	Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)
SPI?	Potentially Y — dietary restrictions / special-needs data collected at RSVP may reveal health or religious SPI (RA 10173 §3(l)). [TO CONFIRM] exact special-data fields captured in the RSVP schema
Recipients / sub-processors	Supabase; event organizer (couple); coordinator within join-permission scope
Cross-border transfer	SG (Supabase)
Retention	Aligned with event retention: 5 years post-event; deletion cascades on guest account deletion (subject to shared-gallery organizer-consent exception, policy §4)
Security measures	RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256
Risk level	Medium (High if dietary/health SPI confirmed)

DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

Field	Detail
Purpose	Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)
Legal basis	Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1)
Data subjects	Guests
Personal data categories	128-dimension face vectors derived from RSVP photo + optional portal upload + on-the-day check-in kiosk
SPI?	Y — BIOMETRIC data (RA 10173 §3(l)). Highest-sensitivity category in the platform
Recipients / sub-processors	Cloudflare R2 per-event encrypted vector index; Supabase (linkage). No cross-border AI sub-processor for the vectors themselves [TO CONFIRM] (matching engine location)
Cross-border transfer	APAC/PH (R2 vector index)
Retention	Per-event lifetime + 5 years; auto-purge with event data. Guest revocation propagates within the next 5-minute refresh cycle (policy §1.4, §4)

Security measures	Per-event scoped — vectors never reused across events ; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag
Risk level	High (biometric SPI)

DPS-05 · Papic / Photo & Video Capture & Delivery

Field	Detail
Purpose	Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering
Legal basis	Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur
Data subjects	Guests, customers (couples); incidental non-account attendees appearing in media
Personal data categories	Photos and video clips; likeness; capture metadata (captured_at, geo when available, device model, paired camera brand/model); tag associations
SPI?	N in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated
Recipients / sub-processors	Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)
Cross-border transfer	APAC/PH (R2)
Retention	Originals: 90 days hot R2 + 5 years IA cold R2 (30-day-post-download compression rule + 5-year hard limit). Geo stripped on outbound shares; original on R2 retains it (policy §4, CLAUDE.md constraint)
Security measures	Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock
Risk level	Medium–High

DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

Field	Detail
Purpose	Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack)
Legal basis	Consent (§12(a)) — mutual, opt-in confirmation required for every edge; life stories rely on existing RSVP photo consent
Data subjects	Customers, guests (adults only — minors NOT processed)

Personal data categories	Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = references (pointers), not copies ; trusted-circle signal = computed on read, not stored
SPI?	Potentially Y — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin derived not stored ; min-N ≥5 on aggregates
Recipients / sub-processors	Supabase (edges + references); no third-party sharing; connections never broadcast/browsable
Cross-border transfer	SG (Supabase)
Retention	Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored
Security measures	Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; no cross-event face recognition ; DPIA completed (Compliance Pack §2, residual Low)
Risk level	Medium — Status: DRAFT, live behind flags; pending DPO/counsel sign-off. Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, not processed

DPS-07 · In-App Communications / Chat (0019)

Field	Detail
Purpose	Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads
Legal basis	Contract (§12(b)) — coordination is core service
Data subjects	Customers, vendors, coordinators
Personal data categories	Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo)
SPI?	N structurally, but free-text/attachments may contain SPI — treat as elevated
Recipients / sub-processors	Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. Video meetings RETIRED 2026-05-16 — no video data stored
Cross-border transfer	SG (Supabase); APAC/PH (R2)
Retention	Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4)
Security measures	RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256

Risk level	Medium
------------	--------

DPS-08 · Payments & Reconciliation (apply-then-pay)

Field	Detail
Purpose	Process PHP-direct service orders: BDO/GCash apply-then-pay, reference codes, manual reconciliation of proof-of-payment against orders
Legal basis	Contract (§12(b)); Legal obligation (§12(c)) — PH tax/BIR record retention
Data subjects	Customers, vendors
Personal data categories	Payment receipts, transaction references, partial bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. No complete card numbers, CVVs, or full bank account numbers stored
SPI?	N
Recipients / sub-processors	Supabase (payments, service_orders, payment_inbox_messages); Setnayan Team (manual reconciliation); Maya Business (V1.5+ gateway [TO CONFIRM] not active)
Cross-border transfer	SG (Supabase)
Retention	Transaction/receipt records: 5 years (tax compliance). Pending orders expire 7 days (policy §4, CLAUDE.md)
Security measures	No card/full-account storage; two-admin approval for refunds >₱10K; append-only audit log; RLS; reference codes 8-char Crockford
Risk level	Medium

DPS-09 · In-App Behavioral / Product Analytics

Field	Detail
Purpose	Platform analytics for Setnayan admins (aggregated); platform improvement + ML model training (anonymized)
Legal basis	Legitimate interest (§12(f)) for aggregated operational analytics; Consent (§12(a)) for the secondary anonymized-training purpose (policy §2.1, §2.2)
Data subjects	Customers, vendors, guests
Personal data categories	In-app activity, surfaces visited, services purchased, vendor interactions, search queries, response/conversion metrics. Aggregated — never individually identified to admins outside dispute-mediation context
SPI?	N

Recipients / sub-processors	Supabase; PostHog [TO CONFIRM] (referenced in repo/iteration 0035; not named in this policy) — no PII per observability design
Cross-border transfer	SG (Supabase); PostHog host [TO CONFIRM]
Retention	Anonymized aggregate: indefinite (no PII). Underlying behavioral rows follow account/event retention (policy §4)
Security measures	Aggregation + de-identification for admin views; no PII in logs; opt-out toggle (per observability design) [TO CONFIRM]
Risk level	Low–Medium

DPS-10 · Email Notifications (Resend)

Field	Detail
Purpose	Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts
Legal basis	Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)
Data subjects	Customers, vendors, guests
Personal data categories	Email address, recipient name, event/order context embedded in the message
SPI?	N
Recipients / sub-processors	Resend (delivery); SendGrid fallback [TO CONFIRM]
Cross-border transfer	US-based email provider likely [TO CONFIRM] (Resend jurisdiction)
Retention	Follows the underlying record; delivery logs [TO CONFIRM] retention at provider
Security measures	TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates
Risk level	Low

DPS-11 · Marketing Site / Cookies & Consent

Field	Detail
Purpose	Public marketing site (setnayan.com); analytics/consent management on public surfaces
Legal basis	Legitimate interest (§12(f)) for essential/first-party operation; Consent (§12(a)) for analytics/advertising cookies

Data subjects	Website visitors (prospective customers/vendors), guests
Personal data categories	Cookie/consent state, IP, user-agent (policy acceptance is logged with timestamp + IP + user-agent), first-party analytics identifiers
SPI?	N
Recipients / sub-processors	Vercel (hosting); analytics processor [TO CONFIRM]. Note: third-party display ads (AdSense) were RETIRED 2026-05-19 — no third-party ad cookies
Cross-border transfer	[TO CONFIRM] (edge/analytics host)
Retention	Consent state persistence [TO CONFIRM] (design referenced 12-month persistence); policy-acceptance log per user retained with account
Security measures	First-party cookie model; consent categories (essential / analytics / advertising); TLS 1.3; HSTS; CSP
Risk level	Low

DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

Field	Detail
Purpose	Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec 03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md
Legal basis	Legitimate interest (§12(f)) — fraud prevention / marketplace integrity. Requires a documented legitimate-interest balancing + disclosure (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) [TO CONFIRM] counsel
Data subjects	Couples / guests (whose device/address/payment signals are clustered — they never see cluster membership) + vendors (scored, and subject to auto-suspend / ban)
Personal data categories	Repurposed inputs (no new collection): device fingerprint (user_devices.device_hash), normalized home address (users.address_normalized), payment-sender identity (payments.reference_number→paying user). Derived: identity cluster_id; per-vendor fraud signals + 0–100 scores with non-PII evidence (counts/ratios/opaque labels); enforcement state + append-only audit. IP deliberately NOT captured
SPI?	N — inputs are personal information, not §3(l) SPI. Elevated because it is involuntary profiling with an automated decision that has a significant effect (vendor livelihood)

Recipients / sub-processors	Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. Service-role / admin ONLY (REVOKE ALL FROM anon, authenticated + is_admin() RLS at CREATE); Setnayan admins via /admin/fraud + two-admin approval gate
Cross-border transfer	SG (Supabase)
Retention	identity_clusters / vendor_fraud_scores = recomputed matviews (no history). fraud_signals + fraud_enforcement_audit persist — explicit retention rule not yet defined [TO CONFIRM] . Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)
Security measures	Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); irreversible ban never automated — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3
Risk level	High — Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected) . DPIA R-08 drafted (08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding

DPS-13 · Vendor AI Assistant — automated replies + business deep-search (0022)

Field	Detail
Purpose	The paid Vendor AI add-on, two capabilities: (a) Auto-reply — reads a couple's inbound messages + Event Brief (event date, guest count, budget-per-head, venue) in that couple↔vendor thread and drafts/auto-sends replies (and, if the vendor allows, accepts a booking) on the vendor's behalf, shown to the couple labelled "■ AI auto-reply"; (b) Deep Search — runs AI web-research over the vendor's own business across public sources (own website, directories, review sites) and stores a structured business dossier (vendor_web_dossiers) the vendor reviews to auto-fill its profile. Both are gated behind the /admin/data-privacy controls vendor_ai_autoreply + vendor_deep_search (fail-closed until DPO-activated)
Legal basis	Contract (§12(b)) — the vendor's paid add-on operating on the vendor's own shop; Consent (§12(a)) — the couple's own act of messaging that vendor grounds the auto-reply reading their thread. Auto-reply is automated processing (§34) with a standing "■ AI auto-reply" label and a §16(c) object path (every message still reaches the vendor). Deep Search of already-public third-party content relies on legitimate interest (§12(f)) , minimised to a business summary with a 180-day retention limit [TO CONFIRM] counsel
Data subjects	Couples (inbound message text + Event Brief the auto-reply reads) + vendors (own business researched, dossier stored) + incidental third parties named on public web pages (Deep Search, e.g. a reviewer's public name)

Personal data categories	Auto-reply: couple inbound chat text + structured Event Brief fields (date, pax, budget band, venue) + the vendor's own package/pricing config; generated reply text. Deep Search: the vendor's own public business info (name, contact, services, review-derived facts) → <u>vendor_web_dossiers</u> . Never consumes SPI, face vectors, religion/faith, or the guest list
SPI?	N — no SPI; biometric, faith, and guest-PII consumption are explicitly carved out
Recipients / sub-processors	Supabase (Postgres, Singapore); Anthropic web_search (US, Deep Search only) — zero-retention API mode. Single-tenant isolation: a vendor's assistant reads only that vendor's own threads/business, never across vendors or across the couple's events
Cross-border transfer	SG (Supabase); US (Anthropic — Deep Search only)
Retention	Deep Search dossier <u>vendor_web_dossiers</u> — rolling 180-day TTL [TO CONFIRM]. Auto-reply reads live thread + Event Brief data in place (no separate store beyond the chat system, DPS-07)
Security measures	Per-vendor single-tenant isolation; both capabilities fail-closed until DPO-activated on the <code>/admin/data-privacy</code> control board; "■ AI auto-reply" transparency label; SPI / face / guest-list carve-out enforced in code; TLS 1.3; AES-256
Risk level	Medium — automated processing (§34) of couple message content + AI web-research that may store incidental third-party PII. Public Privacy Policy §"Vendor AI assistant" + §"Vendor Deep Search" disclosures LIVE ; the <code>/admin/data-privacy</code> controls hold both OFF until DPO sign-off; retention rule + LIA finalization outstanding

DPS-14 · Coordinator Delegated Access — consent scopes + prep-then-release (0021)

Field	Detail
Purpose	Let a couple delegate planning access to a coordinator they invite (a planner / family / friend — host-side, not Setnayan staff). At invite the coordinator accepts an RA 10173 consent modal scoping access to the couple's guest list, seating, schedule, and vendor chats . The couple may optionally grant "Can finalize vendors" and "Can handle payments" scopes (lock vendors + complete an apply-then-pay checkout on the couple's behalf). Prep-then-release lets the coordinator stage run-of-show/schedule blocks privately and release them to the couple (staged blocks hidden from couple/guests/vendors until released). Gated behind the <code>/admin/data-privacy</code> controls <u>coordinator_consent_money</u> + <u>coordinator_prep_release</u> (fail-closed)

Legal basis	Consent (§12(a)) captured on the invite modal + Contract (§12(b)) — service delivery. Money scopes are opt-in by the couple ; consistent with the platform-wide rule that Setnayan never holds, moves, or records the transfer of any money (the coordinator prepares the same off-platform payment; settlement is direct couple↔vendor)
Data subjects	Couples (planning data + optional money authority delegated) + guests (whose PII the coordinator sees within scope) + coordinators
Personal data categories	Guest list + RSVP data, seating, schedule / run-of-show, vendor chat threads — scoped to the granted permissions; optional money-adjacent actions (vendor finalize, checkout) when the couple grants the scope; staged prep-release schedule blocks (hidden until released). Face / biometric data excluded
SPI?	N — no new SPI collection; scoped delegated access to the couple's existing planning data (incl. guest PII)
Recipients / sub-processors	Supabase (Postgres, Singapore) — RLS event/thread scoping + per-thread coordinator join permission (see DPS-07). No new sub-processor
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event data (DPS-01 / DPS-03 / DPS-07) — 5 years post-event. Coordinator access is revocable by the couple at any time; revocation removes access prospectively
Security measures	RLS event/thread scoping; consent captured at invite (durable proof); money scopes opt-in and separately gated; face/biometric excluded; staged prep-release hidden until released; controls fail-closed until DPO-activated; TLS 1.3; AES-256
Risk level	Medium — widens a coordinator's access over guest PII and, if the couple grants it, money-adjacent actions. Public Privacy Policy §"Coordinators you invite" disclosure LIVE ; confirm the DPO ruling before activating the <code>coordinator_consent_money</code> control

2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

#	Registration trigger (Circular 17-01 §4 / related issuances)	Setnayan assessment	Met?
---	---	---------------------	------

1	Processing sensitive personal information of ≥ 1,000 individuals	Setnayan processes SPI: biometric face vectors (DPS-04), government ID + liveness for vendors (DPS-02), and potential health/religious data via RSVP dietary/special needs (DPS-03). Actual count [TO CONFIRM], but a weddings/events platform at scale is very likely to reach ≥1,000 SPI subjects	Likely YES
2	PIC/PIP with ≥ 250 employees	Sole proprietorship; headcount [TO CONFIRM] but almost certainly < 250	No (assumed)
3	Processing is likely to pose a risk to the rights and freedoms of data subjects	Yes — biometric processing, gov-ID + AML screening, guest likeness/media at scale, relationship graph, minors/legacy roadmap, and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood) . This is high-risk processing by nature	YES
4	Processing is not occasional (i.e., regular/systematic core-business processing)	Yes — data processing is the platform's core, continuous business function, not incidental	YES

Conclusion. Registration triggers **#1 (likely), #3, and #4 are met**. Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

Recommendation: Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts [TO CONFIRM] and current NPC registration number [TO CONFIRM] before filing to determine whether this is an initial registration or an amendment.

3. Open items for DPO/counsel before filing

- [TO CONFIRM] Registered business address; headcount; SPI + total data-subject counts; existing NPC registration number.
- [TO CONFIRM] Exact RSVP special-data fields (dietary/health/religious) — determines whether DPS-03 is a formal SPI system.
- [TO CONFIRM] Jurisdictions/retention for Resend, PostHog (analytics), Vercel edge, Suno, and the face-matching engine host.

- [TO CONFIRM] Whether Maya Business (V1.5 payment gateway) is contracted; keep DPS-08 marked "not active" until then.
- DPS-06 (Person Graph) and the Person Graph amendment publish **only after** DPO/counsel sign-off; minors/legacy (Phase 3) require their own DPIA + NPC consultation before any build-to-live.
- DPS-13 (Vendor AI) and DPS-14 (Coordinator Delegated Access) are each held **fail-closed** by the in-app /admin/data-privacy control board; confirm the DPO ruling + finalize the Deep Search retention rule (180-day) before activating the corresponding controls. [TO CONFIRM]

Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.

DPO Designation & Accountability Record + NPC Data Processing System Registration Data Sheet

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05.

This single document holds two related RA 10173 (Data Privacy Act of 2012) filing records for **Setnayan**:
Part A — the Data Protection Officer (DPO) Designation & Accountability record (RA 10173 § 21 accountability + NPC Advisory No. 2017-01 on the designation of DPOs).

Part B — the NPC Data Processing System Registration data sheet: the field-by-field information required to complete registration through the **NPC Registration System (NPCRS)**.

Grounding source for security measures + data flows:

[01 Contracts/Setnayan Privacy and Security Policy.md](#) (Policy v1, locked 2026-05-12; Person-Graph amendment 2026-07-05 in DRAFT). Cross-referenced Records of Processing Activities:

[NPC Compliance/02 Records of Processing Activities_DRAFT_2026-07-05.md](#).

Never-invent rule: every value not supplied verbatim is marked [TO CONFIRM]. Do not guess.

Master fact block (shared by Part A and Part B)

Field	Value
Personal Information Controller (PIC) — legal name	SETNAYAN SOFTWARE DEVELOPMENT SERVICE (sole proprietorship of Indalecio Sacdalan Casasola II)
Business / brand name	Setnayan
Business registration	DTI Business Name Registration No. 8297508 · Territorial scope: National · Validity: 25 June 2026 – 25 June 2031
Registration type	DTI Business Name (sole proprietorship). SEC/CDA: not applicable (sole prop).
BIR registration (Form 2303 / TIN)	[TO CONFIRM]
Proprietor / owner	Indalecio S. Casasola II · owner sign-up email: iscasasolaii@gmail.com
Domains / public surfaces	setnayan.com · setnayan.ph
Registered / principal office address	[TO CONFIRM]
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com
DPO position / title	[TO CONFIRM]
DPO employment basis (employee / contractor / outsourced)	[TO CONFIRM]
DPO other contact (mobile / landline)	[TO CONFIRM]
Total employees / headcount	[TO CONFIRM]

Total number of data subjects	[TO CONFIRM]
Number of data subjects with sensitive personal information	[TO CONFIRM]
Sector / industry	Information & communications technology — online life-events / weddings platform (marketplace + SaaS)

PART A — Data Protection Officer (DPO) Designation & Accountability Record

Prepared under RA 10173 § 21 (Principle of Accountability) and NPC Advisory No. 2017-01 (Designation of Data Protection Officers).

A.1 Appointment

SETNAYAN SOFTWARE DEVELOPMENT SERVICE ("the PIC"), a sole proprietorship of **Indalecio Sacdalan Casasola II**, hereby designates:

Field	Value
Designated DPO	Indalecio Sacdalan Casasola II
Official DPO email	iscasasolaii@gmail.com
Position / title within the organization	[TO CONFIRM]
Employment basis	[TO CONFIRM] (employee / independent contractor / outsourced service provider)
Other contact (mobile / landline)	[TO CONFIRM]
Effectivity date of designation	[TO CONFIRM]
Reports to	The proprietor, Indalecio S. Casasola II (highest management level)

as its **Data Protection Officer**, accountable for the organization's compliance with RA 10173, its Implementing Rules and Regulations, and all applicable NPC issuances.

NPC registration of DPO contact details (required). RA 10173 and NPC issuances require that the DPO's contact details be **registered with the National Privacy Commission** and made available to data subjects and the NPC. The DPO's contact details are carried into Part B (NPC registration data sheet) and are published to data subjects via the Privacy & Security Policy (iscasasolaii@gmail.com). This designation is not complete for NPC purposes until the DPO's details are filed through the NPC Registration System.

A.2 Duties and functions of the DPO

Per NPC Advisory No. 2017-01, the DPO shall, at minimum:

1. **Monitor compliance** — oversee the PIC's compliance with RA 10173, its IRR, NPC issuances, and internal data-protection policies, including the assignment and periodic review of the same.

2. **Advise on Data Privacy Impact Assessments (DPIAs)** — ensure the conduct of DPIAs for new or materially changed processing systems and features; advise the PIC on their necessity, application, and outcomes. *(Explicitly flagged as DPO-first in the Policy's Person-Graph and Minors/Legacy forward-notice — those phases each carry their own guardian-consent mechanics and DPIA before activation.)*
3. **Breach response** — ensure the organization's Personal Data Breach Management procedure (assessment, containment, and the **72-hour NPC notification** and affected-data-subject notification obligations already committed in Policy § 8) is in place and followed; serve as the point of contact during breach handling.
4. **Act as the NPC contact point** — serve as the primary liaison between the PIC and the National Privacy Commission on all matters relating to data privacy and security, including responding to NPC information requests and inquiries.
5. **Handle data-subject requests** — receive, coordinate, and ensure timely response to data-subject requests to be informed, to access, to object, to rectify, to erase/block, to data portability, and to be notified of breaches (Policy § 9 and Appendix A; committed response window: **within 7 business days** for non-urgent requests, **immediate** for breach notifications).
6. **Cultivate awareness** — inform and cultivate awareness on privacy and data-protection matters within the organization, including orientation/training of personnel involved in processing.
7. **Advocate for privacy by design and by default** — advise on embedding privacy safeguards into product design (e.g., RLS access control, per-event-scoped face vectors, signed-URL media access, zero-retention AI mode — see Policy §§ 3, 5, 7, 10).
8. **Maintain records** — support the maintenance of the Records of Processing Activities (RoPA) and the organization's registration with the NPC, and keep both current.
9. **Cooperate with the NPC** — coordinate registration, respond to compliance checks, and facilitate any NPC audit or investigation.

A.3 Independence, resources, and safeguards

- **Independence.** The DPO shall perform the role independently and shall not be dismissed or penalized for performing DPO duties. The DPO shall not hold a position that gives rise to a conflict of interest with the DPO role.
- **PIC = DPO self-designation.** Here the DPO is the proprietor (Indalecio Sacdalan Casasola II), the highest management level — which is itself the concurrent role to assess. NPC Advisory No. 2017-01 favours a DPO with autonomy from the controller; for a **2-person sole proprietorship** the owner acting as DPO is commonly accepted as a practical necessity. **Interim rationale to record (PH counsel to confirm):** no independent employee exists to hold the role, so the proprietor is designated DPO in the interim; the PIC will re-evaluate designating an independent DPO or a **Compliance Officer for Privacy (COP)** as headcount grows. The owner has already registered on the **NPC DPO system (2026-07-07)**.
- **Direct reporting line.** The DPO reports directly to the **highest management level** of the PIC — here, the proprietor, **Indalecio S. Casasola II**.
- **Resources & access.** The PIC shall provide the DPO the resources necessary to carry out the functions above, and timely and unimpeded access to personal data processing activities, systems, and records reasonably required for the role.
- **Involvement.** The DPO shall be involved, in a timely manner, in all issues relating to the protection of personal data.

A.4 Contact details for publication

Channel	Value
---------	-------

DPO email (published to data subjects)	iscasasolaii@gmail.com
In-policy contact point	Policy § 9 — Data subject access / rectification / erasure / restriction / breach inquiries
Breach hotline (severity-high)	[TO CONFIRM] (Policy § 8 references a phone hotline for severity-high incidents)

A.5 Signature block

This designation takes effect on [TO CONFIRM] and remains in force until revoked or superseded in writing.

For the Personal Information Controller (PIC):

Signature	_____
Name	Nandalecio Sacdalan Casasola II
Title	Proprietor, SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Date	_____

Accepted by the Data Protection Officer:

Signature	_____
Name	Nandalecio Sacdalan Casasola II
Title	Data Protection Officer . [TO CONFIRM position]
Date	_____

PART B — NPC Data Processing System Registration Data Sheet

This is the field-by-field information to be entered into the NPC Registration System (NPCRS). Values are drawn from the master fact block; [TO CONFIRM] marks fields that must be settled before filing. The actual online filing is performed by the DPO / owner through the NPC Registration System — this sheet is the data to file, not the filing itself.

B.0 Eligibility / threshold note — assess before filing

NPC mandatory registration of a data processing system is generally triggered when **any** of the following applies to the PIC:

Trigger (mandatory-registration indicator)	Setnayan status
Processes sensitive personal information of at least 1,000 individuals	Likely YES — face vectors + government-ID data + financial reference data are processed for guests, couples, and vendors. Exact count: [TO CONFIRM] (see "number of data subjects with sensitive PII").
Has at least 250 employees	Likely NO — headcount [TO CONFIRM], but a sole-prop startup is almost certainly under 250.
Processing is likely to pose a risk to the rights and freedoms of data subjects	Likely YES — biometric face vectors, government-ID verification, minors/legacy roadmap, cross-border transfers.
Processing is not occasional (i.e., regular / part of core operations)	YES — processing is continuous and central to the platform.

Assessment: at least one, and probably several, mandatory-registration triggers are met (risk to rights + non-occasional processing; and sensitive PII of $\geq 1,000$ is likely once the count is confirmed). **Recommendation:** **register the PIC and its data processing system(s) with the NPC.** The DPO/owner should confirm the sensitive-PII data-subject count [TO CONFIRM] and the employee count [TO CONFIRM] to finalize which triggers formally apply, then file. Even if a specific numeric threshold turned out not to be met, the risk-based and non-occasional triggers independently support registration.

B.1 Personal Information Controller (PIC) details

NPC field	Value
Registered name of PIC	SETNAYAN SOFTWARE DEVELOPMENT SERVICE
Trade / brand name	Setnayan
Type of organization	Sole proprietorship (private)
Business registration	DTI Business Name No. 8297508 (National · valid 25 Jun 2026 – 25 Jun 2031)
SEC / CDA registration	Not applicable (sole proprietorship)
BIR TIN / Form 2303	[TO CONFIRM]
Proprietor / authorized representative	Indalecio Sacdalan Casasola II
Sector / industry classification	Information & communications technology — online platform / marketplace + SaaS (life-events / weddings)

Nature of operations	A Philippines-first life-events platform (V1 surface: weddings). Couples/organizers plan events end-to-end; vendors run business profiles; the Setnayan team runs operations. Includes RSVP + guest management, vendor marketplace & verification, in-app paid services (photo/video capture, livestream, renders, AI-assisted planning), payments (apply-then-pay), and communications.
Principal / registered office address	[TO CONFIRM]
Contact number	[TO CONFIRM]
Official email	[TO CONFIRM] (owner sign-up email on file: iscasasolaii@gmail.com)
Website(s)	setnayan.com · setnayan.ph

B.2 Data Protection Officer details (as filed with NPC)

NPC field	Value
DPO full name	Indalecio Sacdalan Casasola II
DPO position / title	[TO CONFIRM]
DPO email	iscasasolaii@gmail.com
DPO contact number	[TO CONFIRM]
DPO office address	[TO CONFIRM] (default to PIC principal office unless separate)

B.3 Scale of processing

NPC field	Value
Total number of employees	[TO CONFIRM]
Total number of data subjects	[TO CONFIRM]
Number of data subjects whose sensitive personal information is processed	[TO CONFIRM]
Categories of data subjects	Customers (couples / organizers) · Guests · Vendors (business representatives) · (internal: Setnayan team / admins)

B.4 Does the system process sensitive personal information? — YES

Enumerated categories of sensitive personal information / regulated data processed (grounded in Policy §§ 1, 3, 10):

Category	Detail	Data subject	Source in policy
----------	--------	--------------	------------------

Government-issued identifiers	Government-issued ID of vendor primary representative (image), captured for identity + liveness verification	Vendors	Policy § 1.2, § 3.4, § 10 (Persona/Veriff/Onfido)
Biometric data — face vectors	128-dimension face vectors generated from RSVP profile photo + optional pre-event upload + on-the-day check-in kiosk, used for per-event auto-tagging	Guests (and couples where they appear)	Policy § 1.4
Financial reference data	Payment receipts, transaction references, partial bank/e-wallet details for receipts and refunds; vendor payout account details. (Full card numbers, CVVs, and full bank account numbers are NOT stored.)	Customers, Vendors	Policy § 1.1, § 1.2
Sanctions / PEP screening data	Vendor business name + owner name screened against AMLC / ComplyAdvantage sanctions & PEP lists	Vendors	Policy § 3.4, § 10
Health / dietary information (possible)	Guest dietary requirements captured for event catering may reveal health/religious information. Presence and scope in current build: [TO CONFIRM]	Guests	[TO CONFIRM] (not explicitly enumerated in Policy v1 § 1; verify against RoPA + live schema)

Note: some of the above (e.g., government IDs, financial account data) are "sensitive" and/or specially-regulated categories under RA 10173 / related law. Their inclusion here is for completeness of the NPC declaration; the DPO/counsel should confirm final categorization.

B.5 Automated processing / AI decision-making

NPC field	Value
Does the system involve automated processing?	YES — automated processing is used.
AI / automated features present	(a) Automated face-matching auto-tag of event photos (per-event-scoped; confidence-gated). (b) AI contract analysis (Contract Intelligence, Anthropic Claude API, zero-retention mode). (c) AI-assisted planning ("Setnayan AI" — navigational/assistive). (d) Fuzzy payment-inbox → order matching (rule-based). (e) Anti-Fraud identity clustering + vendor fraud scoring + auto-suspend (DPS-12 / DPIA R-08 — live 2026-07-07).

Solely-automated decisions producing legal or similarly significant effects on data subjects?	YES — one, as of 2026-07-07. The Anti-Fraud engine (DPS-12 / R-08) can automatically suspend a vendor's public listing at a high fraud score — a reversible decision with a significant effect. The irreversible wipe/ban is not automated (routed through a two-admin/four-eyes gate). All other automated features remain assistive/human-reviewed (vendor verification + payment reconciliation are admin-reviewed; face auto-tag surfaces suggestions below high-confidence thresholds). Follow-up (RA 10173 §16(c)/§34): document a formal contest/appeal path for the automated suspension — see 08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md §6.
---	--

B.6 Data processing systems / activities (RoPA reference)

The full Records of Processing Activities are maintained separately. **Reference:**

[NPC_Compliance/02_Records_of_Processing_Activities_DRAFT_2026-07-05.md](#) (that RoPA document is the authoritative per-activity list; ensure it exists and is current before filing — status: *[TO CONFIRM – draft to be created/finalized]*).

Indicative data processing systems (to be reconciled with the RoPA):

#	Data processing system	Purpose
1	Customer / guest account & event management	Provide planning, RSVP, guest list, seating
2	Vendor registration & verification	Onboard + verify vendors (ID, permits, sanctions screening)
3	Media capture, storage & auto-tagging	Photo/video/face-vector processing and delivery
4	Payments (apply-then-pay) & reconciliation	Process PHP payments, receipts, refunds
5	Communications (chat)	Couple ↔ vendor / coordinator messaging
6	AI-assisted services	Contract analysis, planning assistance, renders
7	Admin operations & audit	Verification queues, dispute mediation, audit log

B.7 Security measures (summary — full detail in Policy §§ 5, 7, 10)

Area	Measure
Encryption at rest	AES-256 on Supabase Postgres + Cloudflare R2; keys via provider KMS
Encryption in transit	TLS 1.3 on all external connections; HSTS; mixed-content blocked

Access control	Supabase Row-Level Security (per-user isolation); short-lived signed URLs (5-min) for sensitive media; granular admin roles; two-admin approval for high-risk actions; TOTP 2FA (mandatory for admins)
Face-vector safeguards	Per-event scoped, encrypted at rest, never reused across events, "Delete my face data" revocation
Application security	Input validation, parameterized queries, XSS/CSRF protections, rate limiting on auth
Audit	Append-only admin audit log (timestamp, actor, action, before/after, rationale)
Breach response	72-hour NPC + affected-user notification; public summary within 7 days (Policy § 8)
Backups	Daily encrypted DB backups, 30-day retention

B.8 Cross-border data transfers

YES — the system involves cross-border transfers. Primary infrastructure is Singapore + APAC region; several sub-processors are outside ASEAN. All transfers are encrypted in transit (TLS 1.3) and governed by data-processing agreements / SCCs. (Policy § 10.)

Recipient / sub-processor	Jurisdiction	Data shared	Purpose	Lawful basis (per Policy)
Supabase (database)	Singapore	PII + transactional records	Application database (encrypted at rest)	Performance of contract
Cloudflare R2 (object storage)	APAC / PH region	Media originals, face-vector index, documents	Media & document storage	Performance of contract
Vercel (application hosting)	[TO CONFIRM jurisdiction] (US-based)	Application traffic / runtime	Web application hosting	Performance of contract
Resend (email)	[TO CONFIRM jurisdiction] (US-based)	Recipient email + notification content	Transactional / notification email delivery	Performance of contract / legitimate interest
Anthropic (Claude API)	US	Vendor contract text	Contract Intelligence analysis (zero-retention mode)	§ 12(b) legitimate interest; enterprise DPA
Persona / Veriff / Onfido	US	Vendor gov-ID image + selfie + liveness	Vendor identity verification	§ 12(b) — vendor consent at registration
AMLC API / ComplyAdvantage	PH (AMLC) / UK (ComplyAdvantage)	Vendor + owner name	Sanctions / PEP screening	§ 13(d) — compliance with PH AMLA
DTI Database	PH	Vendor DTI Business Name number	Business-registration validation	§ 12(c) — necessity for contract

OpenAI (GPT-4) — V1.5+ fallback only	US	Vendor contract text (fallback)	Contract Intelligence backup	Same as Anthropic
Suno	[TO CONFIRM jurisdiction]	[TO CONFIRM — data shared: AI music generation; confirm whether any personal data is transmitted]	AI music generation for renders (Pakanta / template music)	[TO CONFIRM lawful basis]

The four US sub-processors are bound by SCCs or equivalent DPAs; the Anthropic workspace uses zero-retention API mode; Persona/Veriff/Onfido + AMLC screenings are batch-call-only with no ongoing storage (Policy § 10).

B.9 Filing action & sign-off

- **This document is the DATA to be filed, not the filing itself.** The actual NPC registration of the data processing system(s), and the registration of the DPO's contact details, are **online filing actions performed by the DPO (Indalecio Sacdalan Casasola II) and/or the owner (Indalecio S. Casasola II)** through the **NPC Registration System (NPCRS)**.
- Before filing, resolve **all [TO CONFIRM] fields**, confirm the RoPA (§ B.6) exists and is current, and have the DPO/counsel validate the sensitive-PII categorization (§ B.4) and the automated-decision answer (§ B.5).

Prepared / reviewed	Name	Date
Reviewed by DPO	Indalecio Sacdalan Casasola II	—
Approved by PIC	Indalecio S. Casasola II	—
Filed with NPC (NPCRS) — reference no.	[TO CONFIRM after filing]	—

Footer — This DRAFT establishes a compliant baseline ahead of counsel review. It is not a substitute for legal review. The actual NPC online registration of the data processing system(s) and the registration of the DPO's contact details are the DPO's / owner's filing actions. Finalize with the DPO (Indalecio Sacdalan Casasola II) and Philippine counsel before adoption or submission. · 2026-07-05.

Setnayan — Data Breach / Security Incident Management Policy

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted. · 2026-07-05.

This policy is issued under the Data Privacy Act of 2012 (Republic Act No. 10173, "**RA 10173**"), its Implementing Rules and Regulations (IRR), and **NPC Circular No. 16-03 (Personal Data Breach Management)**. It sets out how SETNAYAN SOFTWARE DEVELOPMENT SERVICE prevents, detects, assesses, contains, and reports personal data breaches and security incidents.

Field	Detail
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name No. 8297508. Brand: Setnayan .
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com
Document owner	Data Protection Officer
Version / date	DRAFT v0.1 · 2026-07-05
Review cadence	At least annually, and after any notifiable breach
Legal basis	RA 10173 §§ 20, 26–31; IRR Rule VIII (Security Measures); Rule IX (Security Incidents & Breaches); NPC Circular 16-03

1. Purpose & Scope

1.1 Purpose

This policy establishes Setnayan's mandatory procedure for managing **security incidents** and **personal data breaches** so that the PIC can:

- prevent breaches through documented organizational, physical, and technical measures;
- detect and assess incidents promptly and consistently;
- **notify the National Privacy Commission (NPC) and affected data subjects within 72 hours** where the breach is notifiable;
- contain, eradicate, and recover from incidents while preserving evidence; and
- maintain records and continuously improve through post-incident review.

1.2 Scope

This policy applies to **all** personal data processed by Setnayan across every processing system, whether stored, transmitted, or handled by:

- Setnayan personnel (the sole proprietor, the DPO, any engaged contractors / team members);
- Setnayan's processing systems — the Next.js web application, admin console, and databases; and

- Setnayan's **sub-processors / personal information processors** (Vercel, Supabase, Cloudflare R2, Resend, Persona/Veriff/Onfido, and any other processor listed in the Privacy & Security Policy § 10).

It covers customer (couple/organizer), vendor, and guest personal data, including **sensitive personal information** and the special category of **face vectors** described in the Privacy & Security Policy § 1.

1.3 Definitions

Term	Meaning (per NPC Circular 16-03 & RA 10173 IRR)
Security incident	An event or occurrence that affects or tends to affect data protection, or may compromise the availability, integrity, or confidentiality of personal data. Includes incidents that would result in a personal data breach if not for safeguards that were in place. All security incidents are logged; not all are breaches.
Personal data breach	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.
Availability breach	Loss, accidental or unlawful destruction, or loss of access to personal data (e.g. R2/Supabase outage causing data loss; ransomware locking records).
Integrity breach	Unauthorized or accidental alteration of personal data (e.g. tampered records, corrupted face-vector store, malicious edits via a compromised admin account).
Confidentiality breach	Unauthorized or accidental disclosure of, or access to, personal data (e.g. leaked credentials, an RLS bypass exposing another user's rows, a mis-issued signed URL).
Sensitive personal information (SPI)	As defined in RA 10173 § 3(l) — includes government-issued IDs, and, for Setnayan, face vectors / biometric data and vendor government-ID images.
Notifiable breach	A personal data breach meeting all the criteria in § 5.2 (SPI or identity-fraud-enabling data, AND real risk of serious harm).
DBRT	Data Breach Response Team (§ 2).
NPC	National Privacy Commission.

2. Data Breach Response Team (DBRT)

Per NPC Circular 16-03 § 5, the PIC constitutes a Data Breach Response Team responsible for the entire incident lifecycle. Given Setnayan's size as a sole proprietorship, roles may be held by the same individual or by engaged contractors, but each **responsibility** below is assigned and accountable.

2.1 Composition & roles

Role	Held by	Core responsibilities
------	---------	-----------------------

DBRT Lead / Data Protection Officer	Indalecio Sacdalan Casasola II - iscasasolaii@gmail.com	Overall accountability; convenes the DBRT; makes the notifiability determination (§ 5); signs and files NPC and data-subject notifications; primary NPC liaison.
PIC / Business Owner	Indalecio Sacdalan Casasola II (SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	Ultimate PIC accountability under RA 10173; approves external communications and remediation spend; authorizes sub-processor escalation.
Technical / Engineering Lead	[TO CONFIRM]	Detection, containment, eradication, recovery; evidence preservation; forensic timeline; coordination with Vercel/Supabase/Cloudflare support.
Security / Operations Coordinator	[TO CONFIRM]	Monitors Sentry / Better Stack / PostHog alerts; triages user-reported incidents; maintains the breach register; runs the annual drill.
Communications / Legal liaison	[TO CONFIRM] (external PH counsel on retainer)	Drafts data-subject notifications and the public setnayan.com/security disclosure; legal review of NPC filings; media handling if applicable.

DBRT contacts (24/7 escalation): [TO CONFIRM] — primary phone, secondary phone, escalation email distribution list.

2.2 Activation & operation

- **Any** Setnayan person or sub-processor notification that suggests a possible breach must be reported to the DPO **and** the Security/Operations Coordinator **immediately** (target: within 1 hour of discovery).
- The DPO convenes the DBRT upon any credible report. The "72-hour clock" begins on **knowledge** of a personal data breach (see § 5.1), not on convening the team — so the DBRT is convened without delay.
- The DBRT operates against the quick-flow in § 10 and documents every step in the breach register (§ 8).

3. Prevention & Preparedness

Setnayan reduces breach likelihood and impact through the organizational, physical, and technical measures below — the operative controls are set out in the **Privacy & Security Policy §§ 5 and 7** and summarized here.

3.1 Technical measures (in place)

Control	Implementation
Deny-by-default access (RLS)	All Postgres queries gate through Supabase Row-Level Security ; no client can read another user's row (Privacy Policy § 5.3). Canonical deny-by-default RLS patterns; RLS enabled at table-creation time.
Encryption in transit	TLS 1.3 on all external connections and WebSocket channels; HSTS enabled; mixed-content blocked (§ 7.2).

Encryption at rest	AES-256 on Supabase Postgres and Cloudflare R2; keys managed by Supabase/Cloudflare KMS. Face vectors stored in a per-event encrypted vector index (§ 7.1, § 1.4).
Least-privilege access	Production DB access restricted to designated roles; granular admin roles; two-admin approval for high-risk actions (role provisioning, refunds/grants > █10K); signed URLs for media are short-lived (5 min for sensitive media) (§ 5.3).
Strong authentication	bcrypt-hashed passwords; OTP/SSO options; TOTP 2FA mandatory for all admin roles (§ 5.1).
Append-only audit log	Every admin action logged with timestamp, actor, action, target, before/after state, rationale; no UPDATE permission ; export restricted (§ 5.4).
Application hardening	Input validation (zod), parameterized queries, React escaping + CSP, CSRF tokens, rate limiting on auth endpoints (§ 7.3).
Encrypted backups	Daily encrypted Postgres backups retained 30 days (§ 7.1) — supports recovery from availability/integrity breaches.

3.2 Monitoring & observability (in place)

- **Sentry** — application error and exception monitoring; anomalous error spikes surface potential incidents.
- **Better Stack** — uptime, heartbeat, and on-call alerting; drives availability-breach detection and the status page.
- **PostHog** — product analytics (opt-out honored, no PII in events) used to spot anomalous behavioral patterns.
- Vercel platform logs; Supabase logs and advisors; Cloudflare R2 access is signed-URL-only (no public reads).

3.3 Organizational measures

- This policy plus the Privacy & Security Policy are the standing breach-management framework.
- **Staff awareness:** every person with data access reads this policy on onboarding and at each annual review; the DBRT runs at least one **table-top breach drill per year**.
- **Sub-processor controls:** all sub-processors are bound by DPAs / SCCs; the Anthropic Console workspace runs zero-retention mode; Persona/Veriff/Onfido and AMLC screenings are batch-call-only (Privacy Policy § 10).
- **Regular review:** this policy, access lists, and the sub-processor register are reviewed at least annually and after any notifiable breach (§ 9).

4. Detection & Assessment

4.1 How incidents are detected

1. **Automated monitoring / alerts** — Sentry error spikes, Better Stack downtime/heartbeat failures, PostHog anomalies, Supabase advisors, auth rate-limit triggers.
2. **User / data-subject reports** — a customer, vendor, or guest reports suspicious activity or exposure via iscasasolaii@gmail.com or in-app support (0029 Help Center ticket).
3. **Sub-processor notifications** — Vercel, Supabase, Cloudflare, Resend, or an identity-verification provider notifies Setnayan of a security event affecting Setnayan data. Setnayan's knowledge for the 72-hour clock arises when it receives such notice with sufficient detail (see § 5.1).

4. **Internal discovery** — a team member or contractor identifies a misconfiguration, leaked credential, RLS gap, or anomalous audit-log entry.

4.2 Initial triage (within 24 hours of discovery)

The Security/Operations Coordinator (or DPO) opens a breach-register entry and records:

- what happened, when discovered, how discovered, systems involved;
- whether **personal data** is involved (if not → security incident only, log and monitor);
- **categories of data** involved (ordinary PII, SPI, face vectors, credentials, financial receipts);
- estimated **number and categories of affected data subjects**; and
- whether the incident is ongoing or contained.

4.3 Severity & notifiability assessment

The DPO assesses severity and applies the notifiability test in § 5.2. If any input is unknown, the DBRT treats the breach as **potentially notifiable** and proceeds toward the 72-hour deadline while facts are confirmed, rather than delaying the clock.

5. The 72-Hour Rule

5.1 When the clock starts

The **72-hour** period runs from the time Setnayan has **knowledge of, or a reasonable belief that, a notifiable personal data breach** has occurred. Knowledge is presumed once the DPO or DBRT has sufficient information to conclude the § 5.2 criteria are (or are likely) met — including on receipt of a sub-processor's breach notice with adequate detail. Setnayan does **not** wait for full forensic certainty before notifying; it notifies within 72 hours and supplements the report as facts develop.

5.2 Notification criteria (all must be present)

Per RA 10173 § 20(f) and NPC Circular 16-03 § 11, notification of the NPC and affected data subjects is **mandatory** when **all three** of the following are met:

1. **There is a personal data breach** (confidentiality, integrity, or availability); **AND**
2. The personal data involved is either **(a) sensitive personal information** — for Setnayan this includes government-issued IDs, **face vectors / biometric data**, and vendor gov-ID images — **OR (b) any other information that may be used to enable identity fraud** (e.g. full name + email + credentials, payment-reference data, partial financial details); **AND**
3. There is a **real risk of serious harm** to the affected data subjects (e.g. identity theft, financial loss, fraud, reputational harm, discrimination, or unauthorized use of biometric identity).

If **any** criterion is absent, the breach is logged in the register (§ 8) and monitored, but NPC/data-subject notification is not mandatory — though Setnayan may still notify voluntarily where prudent. The DPO documents the reasoning either way.

5.3 What must happen within 72 hours

- **Notify the NPC** (§ 6.1) — file the breach notification with the NPC.
- **Notify affected data subjects** (§ 6.2) — in-app + email, per the required content.

Where notification within 72 hours is not feasible, Setnayan may, in **exceptional cases**, request that the NPC allow a delay or a phased notification, giving reasons; and it may postpone data-subject notification **only** to the extent, and for the period, the NPC directs or law-enforcement necessity requires. Any such deviation is documented and approved by the DPO with counsel.

6. Notification Content & Channels

6.1 NPC notification

Channel: filed with the National Privacy Commission via the NPC's prescribed breach-notification means (email / NPC portal as then in force), signed by the DPO.

Contents (NPC Circular 16-03 § 12):

1. **Nature of the breach** — a description of how and when it occurred and the type of breach (availability/integrity/confidentiality).
2. **Personal data possibly involved** — the categories and approximate number of data subjects and records affected (including whether SPI / face vectors).
3. **Measures taken** — actions taken or proposed to address the breach, to secure or recover the data, and to mitigate possible harm; and measures to prevent recurrence.
4. **Name and contact details of the DPO** or other accountable person from whom the NPC can obtain further information.

A **preliminary** notification may be filed within 72 hours with available facts, followed by supplemental submissions as the investigation completes.

6.2 Data-subject notification

Channels: primary — **in-app notice + email (via Resend)** to each affected data subject; a summary disclosure may also be posted at setnayan.com/security where appropriate. Where individual notice is not reasonably possible, the DPO will use a substitute means (e.g. prominent public notice) as the NPC allows.

Contents (must be written in clear, plain language):

1. A description of the **nature of the breach** and the **personal data** possibly involved.
2. **Measures taken** by Setnayan to address the breach.
3. **Measures the data subject may take** to reduce risk (e.g. change password, enable 2FA, monitor bank/e-wallet activity, revoke face data via the "Delete my face data" link).
4. **DPO contact** — iscasasolaii@gmail.com (and severity-high hotline [**TO CONFIRM**]) for questions and assistance.

7. Containment, Eradication & Recovery; Evidence Preservation

7.1 Containment (immediate)

- Isolate affected systems / revoke compromised credentials, tokens, and signed URLs; rotate keys and secrets.
- Disable or lock affected accounts; force re-authentication where credentials may be exposed.
- Engage sub-processor support (Vercel / Supabase / Cloudflare / Resend) to halt ongoing exposure.

- Where an RLS/authorization gap is implicated, deploy an emergency policy fix or take the affected surface offline.

7.2 Eradication

- Remove the root cause — patch the vulnerability, correct the misconfiguration, revoke unauthorized access, remove malicious artifacts.
- Verify no persistence (backdoors, residual tokens, altered RLS policies, injected data).

7.3 Recovery

- Restore data/service from encrypted daily backups where availability/integrity is affected; validate integrity against the audit log before returning to production.
- Monitor closely post-recovery (heightened Sentry/Better Stack watch) for recurrence.

7.4 Evidence preservation

- **Preserve, do not destroy.** Capture and retain logs, timestamps, audit-log excerpts (append-only), Sentry events, access records, sub-processor notices, and system snapshots relevant to the incident **before** remediation alters state where feasible.
- Maintain a chain-of-custody note in the register entry. Evidence supports NPC filings, potential law-enforcement referral, and post-incident review.

8. Documentation & Record-Keeping

8.1 Breach register (mandatory)

Setnayan maintains a **breach register** recording **all** security incidents and personal data breaches — notifiable or not — per NPC Circular 16-03 § 14. The register is maintained by the Security/Operations Coordinator under DPO oversight and stored access-restricted. Template in § 10.

8.2 Annual report to the NPC

Setnayan submits an **annual report of the summary of security incidents and personal data breaches** to the NPC in the form and period the NPC prescribes. The DPO compiles this from the breach register.

8.3 Retention

Breach-register entries and supporting evidence are retained consistent with the Privacy & Security Policy § 4 audit-log retention (**5 years**) and any longer period required for pending NPC or legal proceedings.

9. Post-Incident Review

After every notifiable breach (and periodically for aggregated non-notifiable incidents), the DBRT conducts a documented review covering:

- **Root-cause analysis** — the technical and organizational cause, and why existing controls did not prevent it.
- **Remediation** — permanent fixes, additional controls, and verification that they work.

- **Policy & control update** — amend this policy, the Privacy & Security Policy, RLS patterns, monitoring rules, access lists, or sub-processor terms as needed.
- **Awareness** — brief the team; update onboarding materials; schedule/refresh the annual drill.
- The DPO signs off the review; changes to this policy follow the review cadence in the header.

10. Incident Response Quick-Flow & Breach Register Template

10.1 Quick-flow (one page)

SETNAYAN INCIDENT RESPONSE – QUICK-FLOW	
(72-hour clock starts on KNOWLEDGE of a notifiable breach)	
1. DETECT	
Sentry / Better Stack alert · user report (iscasasolaii@gmail.com) ·	
sub-processor notice · internal discovery	
report to DPO + Ops Coordinator ≤ 1 hour	
2. CONTAIN	
Isolate systems · revoke credentials/tokens/signed URLs · rotate keys ·	
lock affected accounts · engage sub-processor support	
>> PRESERVE EVIDENCE (logs, audit trail, snapshots)	
3. ASSESS (DPO)	
Personal data involved? ■■■No■■■ log as security incident, monitor	
■■ Yes	
NOTIFIABILITY TEST – ALL three?	
(1) personal data breach AND	
(2) SPI / face vectors OR identity-fraud-enabling data AND	
(3) real risk of serious harm	
■■ No ■■■ record in register + reasoning, monitor	
■■ Yes / Uncertain	
4. NOTIFY ≤ 72 HOURS from knowledge	
• NPC – nature · data involved · measures taken · DPO contact	
• Affected data subjects – in-app + email (Resend); what happened,	
what we did, what they should do, DPO contact	
• (as appropriate) public notice at setnayan.com/security	
5. REMEDIATE	
Eradicate root cause · recover from encrypted backups · verify	
integrity vs audit log · heightened monitoring	
6. REVIEW	
Root-cause · remediation · update policy/controls · record in register	
· feed the annual NPC summary report	

10.2 Breach register template

FCC #	Data (i.e. a + r)	s N C	C Containment	DPO sign-off
2020-001	row) Confidentiality / photos, signed-URL misconfiguration		Open	
			Closed	

Legend — breach type: A = Availability · I = Integrity · C = Confidentiality. **Notifiable?** applies the § 5.2 three-part test; record the reason in either direction.

Appendix — Cross-references

- **Setnayan Privacy & Security Policy** — § 5 (access control & audit log), § 7 (security practices), § 8 (breach notification), § 10 (sub-processors & cross-border transfers).
- **NPC Circular 16-03** — Personal Data Breach Management (governing circular for this policy).
- **RA 10173** §§ 20, 26–31 and IRR Rules VIII–IX.
- **0028 Email Notifications** — security_alert template used for data-subject notification via Resend.
- **0023 Admin Console** — append-only audit log and role-based access supporting detection and evidence.

Compliant baseline ahead of counsel review; not a substitute for legal review. This DRAFT must be finalized and adopted by the DPO (Indalecio Sacdalan Casasola II) and PH counsel before it takes effect.

Data Privacy Impact Assessment (DPIA) Register + Person Graph DPIA

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted. · 2026-07-05

Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This register indexes every Setnayan processing system that warrants a DPIA and records its assessment status; Part 2 is the first fully-worked DPIA (the adults-only Person Graph).

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com · registered (or registration in progress [TO CONFIRM]) with the NPC
Register owner	DPO (Indalecio Sacdalan Casasola II)
Key infrastructure / processors	Vercel (hosting) · Supabase (Postgres, Singapore region) · Cloudflare R2 (object storage, APAC/PH region) · Resend (transactional email) · Persona / Veriff / Onfido (vendor ID + liveness) · Anthropic (Claude API) / OpenAI (fallback) · AMLC API / ComplyAdvantage (sanctions screening) · DTI Database (business-registration validation)
Governing policy	01_Contracts/Setnayan_Privacy_and_Security_Policy.md (v1, locked 2026-05-12; Person-Graph amendment 2026-07-05 in DRAFT)
Register status	DRAFT — pending DPO adoption
Register version / date	2026-07-05

Part 1 — DPIA Register (index)

Each row is a distinct processing system (or coherent processing activity) assessed for whether it warrants a DPIA, and, if so, the DPIA's current status.

Status legend: **Complete** = full DPIA finished and DPO-signed · **In-progress** = DPIA drafting/assessment underway · **Pending — counsel-first** = DPIA required before or alongside build; must be reviewed by PH counsel + DPO before the processing goes live (or, where noted, before it is designed).

Risk-level legend: HIGH / MED / LOW = inherent risk to data-subject rights and freedoms before residual-control weighting (biometric, government-ID, financial, minors, and involuntary-inference processing default to HIGH).

#	Processing system	Data-subject(s)	Sensitive-data trigger	Risk level	DPIA status	DPIA owner	Last reviewed
R-01	Face vectors / biometric auto-tagging — 128-dim per-event face vectors from RSVP photo + portal upload + check-in kiosk, used to auto-tag gallery photos	Guests	Biometric = sensitive personal information (RA 10173 § 3(l))	HIGH	In-progress — counsel-first — full DPIA now DRAFTED: see 06_DPIA_Face_Vectors_DRAFT_2026-07-05.md. Headline finding: current "implicit consent" via RSVP photo upload is likely insufficient for biometric data — explicit, separate, evidenced face-recognition opt-in required before wider rollout. Pending DPO/counsel sign-off.	DPO	[TO CONFIRM date]
R-02	Person Graph (connections + life-story references + trusted-circle signal), adults-only	Adult account holders + claimed/seeded persons	Relationship data; potential sensitive inference	MED (residual Low)	Complete — see Part 2 of this document	DPO	2026-07-05 (this draft)

R-03	Vendor verification — government ID, liveness/selfie, DTI/BIR permits, AMLC sanctions/PEP screening, client-reference calls	Vendors (primary representatives)	Government-issued ID; liveness biometrics; AMLC watchlist screening	HIGH	Pending — counsel-first — processing is live in code; DPIA to be formalized. Covers Persona/Veriff/Onfido, AMLC/ComplyAdvantage, DTI Database sub-processors + cross-border transfer (US).	DPO	[TO CONFIRM date]
R-04	Payments & reconciliation — apply-then-pay orders, BDO/GCash reference matching, partial bank/e-wallet details on receipts, payment-inbox reconciliation	Customers, vendors	Financial data (partial account identifiers; transaction history)	MED	Pending — DPIA to be written; note no full card/CVV/account numbers stored (§ 1.1 of policy).	DPO	[TO CONFIRM date]
R-05	Minors & Legacy (Phase 3 — stewarded / branch accounts) — guardian-held child memories to age of majority; post-mortem legacy transfer down the family line	Minors; deceased persons' data; guardians/heirs	Data about minors; post-mortem control; guardianship consent	HIGH	Pending — counsel-first · NOT PROCESSED YET — adults-only today; no minor data is processed. A full DPIA + NPC consultation is required before any design-to-build , not merely before launch. FLAGGED. Instrument: Phase3_Minors_and_Legacy_Counsel_Brief_2026-07	DPO	[TO CONFIRM date]

R-06	Contract Intelligence (0032) — vendor contract text extracted from uploads, sent to Claude API (Anthropic, US; OpenAI fallback) for analysis	Vendors, and third parties named in contracts	Cross-border transfer to US LLM sub-processor; possibly sensitive contract terms	MED	Pending [TO CONFIRM] — Anthropic zero-retention mode + SCCs in place (policy § 10); DPIA to confirm scope. Listed for completeness; owner to confirm whether it merits a standalone DPIA or folds under R-03/vendor processing.	DPO	[TO CONFIRM date]
R-07	Chat / communications (0019) — customer↔vendor messages, thread file attachments (docs/images/PDF), pasted external meeting links	Customers, vendors, coordinators, customer↔vendor questions	Free-text messages may contain incidental sensitive data	LOW-MED	Pending [TO CONFIRM] — video meetings retired 2026-05-16 (no video data stored); text + files persist to Postgres/R2. Owner to confirm standalone vs. folded.	DPO	[TO CONFIRM date]

R-08	Anti-Fraud & Trust Integrity — identity clustering (shared device/address/payment), per-cluster de-dup of vendor trust stats, vendor fraud scoring, + two-stage enforcement (reversible auto-suspend + four-eyes wipe/ban)	Couples/guests (identity-clustered) + vendors (scored/enforced),	Involuntary profiling + automated decision with significant effects (auto-suspend / ban); repurposed device/address/payment personal data	HIGH	In-progress — counsel-first · LIVE AHEAD OF SIGN-OFF — full DPIA now DRAFTED: see 08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md Shipped to prod 2026-07-07 (PRs #2834/#2835/#2836/#2838/#2841) ahead of counsel review (owner-elected). Headline finding: processing is undisclosed — a Privacy Policy Anti-Fraud amendment (notice + § 12(f) basis + right to object) + a documented LIA + a formal automated-decision contest path are required. Pending DPO/counsel sign-off.	DPO	[TO CONFIRM date]
------	---	--	--	-------------	---	-----	-------------------

Notes on the register.

- Rows R-06 and R-07 are listed for completeness and are candidates for consolidation into adjacent DPIAs at the DPO's discretion; they are **not** the priority items.
- The four priority items for counsel are **R-01 (biometric)**, **R-03 (vendor ID)**, **R-05 (minors/legacy)**, and — for confirmation of two narrow bases only — **R-02 (person graph)**. **R-08 (anti-fraud) is now a fifth priority — and uniquely urgent because it is already LIVE in production ahead of counsel review** (see **08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md** status banner); its transparency/disclosure gap should be closed promptly.
- [TO CONFIRM date] in every "Last reviewed" cell must be set by the DPO on adoption; R-02's review date is the date this draft is signed off.

Part 2 — Full DPIA: Person Graph (adults-only)

Formalizes and expands the self-assessment in

03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md § 2 into the NPC PIA/DPIA structure.

Scope is strictly the **adults-only** Phase-2 person-graph features live behind flags as of 2026-07-05. **Minors and legacy (Phase 3) are expressly out of scope** and carry their own counsel-first DPIA (register R-05).

2.1 Description of the processing

What is processed.

- **Person node** — a durable profile: name, optional photo, and the list of events the person takes part in. Every account is one person; a person may also be *seeded* by a host (e.g. added as a guest) and later *claimed* by the real person so their own history follows them.
- **Connections** — a relationship edge between two people. Type $\in$ {spouse, parent, sibling, child, godparent, friend}; state $\in$ {pending $\rightarrow$ confirmed}. Extended/derived relationships (grandparents, cousins, in-laws) are **computed on read, never stored**.
- **Life-story items** — **references (pointers), not copies**, to a photo/clip/editorial the person appears in, so the item can also surface in that person's own private archive. No image bytes are duplicated; media stays in its single system-of-record (R2).
- **Trusted-circle signal** — a **computed, aggregated** count of how many people in a person's circle explicitly endorsed a given vendor. **Not stored** as a per-person record.

Why (purpose). To let a person's memories and confirmed relationships follow them across events (the product's core "living memories" purpose), and to surface aggregate, consent-based vendor trust signals — without building a browsable social directory or any advertising/data-broker use.

Data subjects. Adult Setnayan account holders and adult persons seeded by a host and not-yet-claimed. No minors.

Data categories.

- Identity: name, optional photo (already collected under policy § 1.1/§ 1.3).
- Relationship: first-degree declared edges only; extended kin derived, not stored.
- Content references: pointers to media the person appears in (governed by the source media's own consent + retention).
- Derived/aggregate: trusted-circle count (computed, not stored).
- **Not collected here:** contact details of connected persons (name-only visibility), face/biometric origin (no face field in the graph schema), booking history as a trust input.

Systems / data flows.

1. Person A initiates a connection request $\rightarrow$ B receives a just-in-time notice $\rightarrow$ B confirms or declines.
2. Edge becomes real **only on mutual confirmation**; declined edges are suppressed immediately.
3. Life-story references are assembled from events where photo-sharing consent was given at RSVP; the person can hide any item or opt out of an event's story without touching the host's gallery.
4. Trusted-circle score is computed at read time from **explicit endorsements/reviews only**, gated by min-N $\geq$ 5, degree $\leq$ 2, never from bookings, never purchasable.
5. Storage: `person_connections` (edges) + `person_story_items` (references) in Supabase Postgres (Singapore); referenced media in Cloudflare R2 (APAC/PH). Deny-by-default RLS; participant-scoped access only.

2.2 Necessity & proportionality assessment

- **Lawful basis.** Consent (RA 10173 § 12(a)) via mutual confirmation for connections; existing event photo-consent (RSVP) for life-story references; legitimate interest / aggregate-only for the trusted-circle signal, gated so no individual is identifiable. [TO CONFIRM] — DPO/counsel to confirm the precise § 12/§ 13 basis

mapping per data category.

- **Necessity.** Each element is necessary for the stated purpose: connections require the counterpart's identity to be meaningful; life-story references require a pointer to the source media; the trusted-circle signal requires endorsement counts. No element collects more than the purpose needs.
- **Proportionality / minimization applied.**
 - Only **declared first-degree edges** are persisted; extended kin is derived, not stored.
 - Cross-person visibility is **name-only** — no contact details cross the edge.
 - Life-story items are **references, not copies** — no media duplication.
 - Trusted-circle is **computed, not stored**, and **aggregated (min-N ≥ 5)**.
 - The graph is **not browsable** — no "people you may know", no directory, no broadcast.
- **Conclusion.** The processing is necessary and proportionate to the purpose, with data minimization enforced structurally (schema + RLS), not merely by policy.

2.3 Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). Two narrow items (cross-event archiving basis; long-lived memory retention basis) are referred to the DPO/counsel for confirmation — see § 2.5.
- **Data subjects:** consulted at the point of processing via just-in-time consent/notice strings (drafted in the Compliance Pack § 1) rather than a formal survey; mutual-confirmation design means no processing occurs without the counterpart's active choice.
- **External counsel / NPC:** not required for the adults-only graph beyond the two confirmation items; **required** before any Phase-3 (minors/legacy) work (register R-05).

2.4 Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
PG-1	Exposing a person's data to someone they did not consent to	High	High	High	Mutual confirmation required; name-only, confirmed-only cross-person visibility (SQL <code>visible_connection_names</code>); no contact details cross the edge; deny-by-default RLS	Low

PG-2	The graph becoming a browsable social directory	Med	High	High	Participant-scoped RLS; no "people you may know"; no browse/search; edges private to the two people only	Low
PG-3	A person's photo appearing in another's archive without a basis	Med	High	Med-High	Built on event-level photo consent (RSVP); per-person hide + per-event opt-out ; references not copies ; host gallery untouched	Low-Med — cross-event archiving basis to be confirmed with counsel (see § 2.5)
PG-4	Inferring sensitive information from relationship data	Med	Med	Med	Extended kin derived, not stored ; min-N ≥ 5 on any aggregate; only declared first-degree edges persisted	Low
PG-5	Vendor recommendations exposing who-used-whom	Med	High	Med-High	Aggregate-only; min-N ≥ 5 ; explicit-endorsement-only (never bookings); degree ≤ 2 ; not purchasable	Low
PG-6	Cross-event face recognition / biometric creep	High	High	High	Structurally impossible in this schema — association is tag/QR/confirmed-identity only; no face origin field; face vectors stay per-event (policy § 1.4)	Low

PG-7	Pending requests leaking a name before consent	Med	Med	Med	Names resolve only for confirmed edges ; pending requests show a neutral label	Low
PG-8	Data kept longer than justified (over-retention)	Med	Med	Med	Follows event/account retention (policy § 4); hide/opt-out takes effect immediately; a reference dies with its source media	Low–Med — long-lived "memory" retention basis to be confirmed with counsel (see § 2.5)

2.5 Residual-risk conclusion

Residual risk across the person graph is **Low overall**. The design applies data minimization and consent structurally — mutual confirmation, name-only + confirmed-only visibility, min-N ≥ 5 aggregation, references-not-copies, per-person hide / per-event opt-out, no cross-event face recognition, and deny-by-default RLS — so the two highest inherent risks (PG-1, PG-6) reduce to Low.

Two items are flagged for counsel confirmation (not redesign):

- PG-3 — cross-event photo archiving basis.** Confirm that the event-level RSVP photo consent is an adequate lawful basis for a photo the person appears in to also surface in *their own* private archive across events. (Counsel brief §4.4 reference.)
- PG-8 — long-lived "memory" retention basis.** Confirm the lawful basis and disclosure for intentionally long-lived preservation of memories (the product's purpose), so retention is justified-and-disclosed rather than open-ended.

Recommendation. Proceed with the adults-only person graph **once (a) the Privacy Policy Person-Graph amendment (2026-07-05) is approved and (b) the two confirmation items above are answered** by the DPO/counsel. No redesign is indicated.

2.6 Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	_____	[TO CONFIRM date]
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	_____	[TO CONFIRM date]

Next review date: [TO CONFIRM date] (recommend: at any material change to the person-graph schema/consent, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The Person-Graph Privacy Policy amendment publishes only

after sign-off; the biometric (R-01), vendor-verification (R-03), and minors/legacy (R-05) DPIAs remain outstanding and counsel-first.

Data Privacy Impact Assessment (DPIA) — Face Vectors / Biometric Auto-Tagging

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted. · 2026-07-05

Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-01** (05_DPIA_Register_DRAFT_2026-07-05.md) — **HIGH-risk** because it processes **biometric data**, which is **sensitive personal information** under RA 10173 § 3(I). A full, dedicated assessment is warranted precisely because a face vector is not ordinary PII.

■ CORRECTION — verified against shipped code 2026-07-05 (read first)

This DPIA's **headline finding (BV-1 / §6) is SUPERSEDED**. It was drafted from the Privacy Policy §6.1's "implicit consent" wording — but that wording was **stale**. Verified in production code:

- app/[slug]/_components/selfie-capture.tsx — the face-recognition consent is an **explicit, separate checkbox** (name="biometric_consent", label "face recognition for this wedding"), **defaulted OFF** (useState(false)); un-checking it drops the selfie.
- app/[slug]/actions.ts (RSVP) **and** app/papic/face-enroll-actions.ts (day-of) both **refuse to create a face vector unless biometric_consent === '1'**, and stamp consent_at + consent_source on the enrolment (the evidenced record).

So the **explicit, separate, evidenced, default-OFF opt-in that §6 recommends is ALREADY SHIPPED** (owner directives 2026-06-05 / 2026-06-28). **BV-1 is substantially RESOLVED in production** → its residual is **Low**, not Med–High. The Privacy Policy §6.1 has been corrected to match (2026-07-05).

The genuinely open headline finding is now BV-8 — MINORS: guests carry no age/birth-date field, so nothing prevents a minor's face from being enrolled (a minor, or a guardian on their behalf, can tick the box). That is the live gap to close, and it is counsel-first. Read §6's recommendation as **"maintain + keep the policy accurate,"** not "implement."

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com · registered (or registration in progress [TO CONFIRM]) with the NPC
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Face vectors / biometric auto-tagging (Papic) — register R-01
Governing policy	01_Contracts/Setnayan_Privacy_and_Security_Policy.md § 1.4 (Face vectors), § 2.1 (auto-tag purpose), § 3.2 (media/vector storage), § 4 (retention), § 6.1 (photo/likeness consent)

Feature specs	0012_paparazzi/ (Papic capture → upload → tag) + 10_Papic_Feature_Specification.md
Risk level (inherent)	HIGH — biometric = sensitive personal information
DPIA status	DRAFT — pending DPO adoption + PH counsel review (counsel-first per register)
Version / date	2026-07-05

1. Description of the processing

1.1 What a face vector is

A **face vector** is a **128-dimension** numerical representation ("embedding") computed from a photograph of a person's face. It is not the photo itself — it is a mathematical fingerprint of the face's geometry that lets the system compare two faces for similarity. Under RA 10173 § 3(l), a template derived from a person's face for the purpose of identifying that person is **biometric data**, and biometric data is **sensitive personal information** (§ 3, and see § 12–13 for the heightened processing conditions that follow).

1.2 Why it is processed (purpose)

To **auto-tag guests in a specific event's photo gallery** (the Papic candid-capture service). When a paparazzo or another guest uploads a photo, the system compares faces in that photo against the enrolled guest vectors **for that event only**, and tags matches so each guest's tagged photos surface to them in their gallery and personal-reel builder (policy § 2.1: "Auto-tag photos via face matching (couple-scoped only)").

1.3 Data flow (capture → vector → match → tag → gallery)

1. **Capture / enrolment sources** (policy § 1.4) — a guest's face vector is enrolled from one or more of:
 - the guest's **RSVP profile photo**,
 - an **optional pre-event portal upload**,
 - the **on-the-day check-in kiosk**.
2. **Vector generation** — a 128-dim vector is computed from the enrolment image and written to a **per-event encrypted vector store** (policy § 3.2). The enrolment image itself is governed by the media rules in § 1.3/§ 3.2/§ 4.
3. **Per-event match at upload time** — when a photo/clip lands in the event gallery, detected faces are compared **only against that event's vector store**. Confidence thresholds:
 - **≥ 0.85** → **auto-tag** the guest,
 - **0.65–0.85** → surface a **suggested tag** for human confirmation,
 - **< 0.65** → the photo **uploads untagged** (still delivered — see § 5).
4. **Tag → gallery** — the resulting tag routes the photo into the matched guest's tagged-photos view; untagged photos still land in the couple's gallery (untagged-still-delivered guarantee).
5. **Revocation / expiry** — a guest "Delete my face data" link revokes enrolment within the **next 5-minute refresh cycle**; turning the **Photo Consent** toggle OFF revokes live enrolment and clears any selfie display photo; vectors are otherwise **deleted at the 5-year retention boundary** with the event data (policy § 4).

1.4 Data subjects

Guests (adults). Minors are excluded from the person-graph today; **whether child guests can be enrolled in face auto-tagging under the current build is [TO CONFIRM]** — this must be answered before adoption (see risk BV-8).

No vendor, couple, or admin faces are enrolled for auto-tagging.

1.5 Systems, storage, and retention

- **Vector store:** per-event, **encrypted at rest** (policy § 1.4, § 3.2, § 7.1 AES-256). Never reused across events/weddings.
- **Enrolment / gallery media:** Cloudflare **R2 (APAC/PH region)**, signed-URL access only (policy § 3.2).
- **Matching engine host / location:** [TO CONFIRM] — the compute location and any sub-processor for the face-embedding/matching step is not recorded in the policy and must be confirmed (implicates § 10 cross-border analysis if it runs outside SG/PH).
- **Retention:** face vectors kept for the **per-event lifetime + 5 years**, then **auto-purged with the event data** (policy § 4). Earlier deletion via the guest "Delete my face data" link or Photo Consent OFF.
- **Database of record for tags/linkage:** Supabase Postgres (Singapore), RLS-gated (policy § 3.1).

2. Necessity & proportionality assessment

2.1 Is biometric auto-tagging *necessary* for the purpose?

The purpose — getting each guest their own photos out of a large shared event gallery — is legitimate and central to Paptic. Face auto-tagging makes that **convenient and complete at scale**, but it is **not the only means** of achieving it.

Less-intrusive alternatives already exist in the product:

- **Manual tagging** — the couple / guests tag photos by hand.
- **QR tagging** — the paparazzo scans a guest's personal QR (`setnayan:guest:{id}`) or a table QR (`setnayan:table:{id}`) to tag, with table-tag fan-out to seated guests (capped at 10 tags/photo). This is a first-class, already-shipped tagging path in the Paptic spec that requires **no biometric processing at all**.

Because QR and manual tagging deliver the same core outcome without processing sensitive biometric data, face auto-tagging is best characterized as a **convenience/coverage enhancement layered on top of non-biometric tagging**, not a strict necessity. This framing matters for the consent standard (§ 6): a non-essential, sensitive-data feature should be **separately opt-in**, and a guest who declines it should still get full non-biometric service.

2.2 Proportionality — is biometric justified given the alternatives, and is it minimized?

On balance the biometric layer can be **proportionate**, *conditional on the consent fix in § 6*, because the design already minimizes it structurally:

- **Per-event scoping** — vectors are **never reused across events/weddings**; the store is siloed per wedding, so there is no cross-event identification capability and no growing biometric identity graph.
- **Thresholds tuned to reduce harm** — ≥ 0.85 to auto-tag, a human-in-the-loop **suggested-tag** band (0.65–0.85), and **< 0.65 uploads untagged** rather than guessing.
- **Untagged-still-delivered** — the feature is not load-bearing for photo delivery; a face that never matches still reaches the couple's gallery, so declining biometrics costs the guest nothing structural.
- **Purpose-limited** — vectors are used **only** to tag within the one event; policy § 2.3 forbids sale, cross-vendor sharing, and out-of-platform advertising.
- **Revocable + time-boxed** — "Delete my face data" (≤ 5 -min revocation), Photo Consent OFF, and the 5-year hard deletion.

Conclusion. The processing can be proportionate **only if** (a) the feature stays a genuine opt-in overlay on non-biometric tagging (which it is), and (b) the **consent standard is upgraded to explicit, separate, evidenced opt-in for face recognition** (§ 6). Absent (b), the sensitive-data processing is **not adequately justified** against the available less-intrusive alternatives.

3. Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The headline consent-standard question (§ 6) and the open [TO CONFIRM] items (minor enrolment; matching-engine location) are referred to the DPO and PH counsel for confirmation.
- **Data subjects (guests):** consulted at the point of processing via the RSVP/portal/kiosk consent surfaces and the in-profile **Photo Consent** toggle. **This DPIA finds the current guest-facing consent moment insufficient for biometric data** and recommends a dedicated, separate face-recognition opt-in string (§ 6) — the consultation mechanism exists but its content must be upgraded.
- **External counsel / NPC:** **required** before wider rollout (register R-01 is "counsel-first"). Counsel to confirm the § 6 consent standard, the minor-enrolment position, and whether an NPC consultation is advisable given the biometric + event-guest population.

4. Risk assessment table (biometric-specific)

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§ 5). Biometric processing starts HIGH by default.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
BV-1	Processing sensitive biometric data without a valid consent standard — "implicit consent" from an RSVP photo upload may not meet the RA 10173 § 3(b)/§ 12–13 bar of <i>freely given, specific, informed, and evidenced</i> consent for sensitive data (see § 6, KEY FINDING)	High	High	High	Opt-in framing + Photo Consent OFF toggle + untagged-still-delivery (declining costs nothing)	Med–High — NOT resolved by current controls. Reduces to Low only after an explicit, separate, evidenced face-recognition opt-in is added (§ 6). Headline gap.

BV-2	Function creep / cross-event identification — vectors reused to identify a person across weddings, building a biometric identity graph	Med	High	High	Per-event scoping — vectors NEVER reused across events (policy § 1.4). No cross-event vector store; person-graph schema has no face field (DPIA 05 PG-6)	Low
BV-3	Vector breach or theft — biometric templates exfiltrated; a face cannot be reset like a password	Med	High	High	Encrypted at rest (AES-256, policy § 1.4/§ 7.1); per-event silo limits blast radius; signed-URL-only media; RLS; 72-hr NPC + user breach notice (§ 8)	Low–Med — residual impact stays elevated because biometrics are irrevocable; [TO CONFIRM] whether vectors are separately key-scoped per event and whether raw enrolment images are purged post-vectorization
BV-4	Misidentification / wrong-tag harm — a guest tagged in a photo that isn't them (or vice-versa), causing embarrassment or mis-delivery	Med	Med	Med	Threshold ladder (≥ 0.85 auto · 0.65–0.85 human-confirmed suggestion · < 0.65 untagged); couple review window before public unlock; max 10 tags/photo	Low

BV-5	Inability to withdraw / exercise erasure — a guest cannot effectively revoke enrolment	Med	High	Med–High	"Delete my face data" link ($\leq$ 5-min revocation); Photo Consent OFF revokes live enrolment + clears selfie; account-deletion cascade to face vectors (policy § 4)	Low
BV-6	Covert or non-consensual capture (paparazzi) — a guest photographed/enrolled without a real choice	Med	High	Med–High	Paparazzi opt-out with face-blur for opted-out guests (policy § 6.1); NSFW filter always-on	Low–Med — depends on the § 6 consent fix and on opt-out being surfaced <i>before</i> capture, not only after [TO CONFIRM]
BV-7	Re-identification from vectors — a stored 128-dim template reverse-engineered or matched against an external face database	Low	High	Med	Per-event silo (no cross-event corpus to link against); encryption at rest; no sale/sharing (§ 2.3); no external face DB used	Low
BV-8	Child / minor faces enrolled — a minor guest's biometric processed without lawful guardian consent	[TO CONFIRM]	High	High	Minors excluded from person-graph; whether the auto-tag enrolment path itself blocks minors is [TO CONFIRM]	[TO CONFIRM] — cannot be rated Low until minor-enrolment behavior is confirmed and, if enrolment is possible, blocked or guardian-consent-gated
BV-9	Retention beyond necessity — vectors kept longer than needed for tagging	Low	Med	Med	5-year hard deletion with event data; earlier deletion via link/toggle; auto-purge (policy § 4)	Low

5. Controls already built

The following controls exist in the shipped design and are load-bearing for the residual ratings above:

- **Opt-in enrolment + Photo Consent OFF toggle** — enrolment originates from a guest-supplied RSVP/portal/kiosk photo; the profile **Photo Consent** toggle turns face detection off at any time (policy § 6.1). *(Note: this DPIA finds the opt-in standard itself insufficient for sensitive data — see § 6.)*
- **Per-event scoping — vectors NEVER reused across events (policy § 1.4)** — the single most important control against function creep and cross-event identification.
- **Confidence thresholds** — ≥ 0.85 auto-tag · $0.65\text{--}0.85$ human-confirmed suggestion · < 0.65 untagged.
- **"Delete my face data" link + ≤ 5 -minute revocation cycle**, and Photo Consent OFF revokes live enrolment + clears any selfie display photo.
- **5-year deletion** — vectors auto-purge with event data at the retention boundary (policy § 4); account-deletion cascades to face vectors (§ 4).
- **Face-blur for paparazzi opt-outs** — opted-out guests are face-blurred in captures (policy § 6.1).
- **Encryption at rest** — per-event vector store encrypted (AES-256), signed-URL-only media, RLS-gated linkage tables (policy § 1.4/§ 3.1/§ 3.2/§ 7.1).
- **NSFW filter always-on** and **couple review window** before public unlock (per Papic constraints).
- **Untagged-still-delivered guarantee** — declining biometrics never blocks a guest's photos from reaching the gallery.

6. KEY FINDING — the consent standard for biometric data (headline)

Finding. RA 10173 treats biometric data as **sensitive personal information**, and its processing requires consent that is **freely given, specific, informed, and EVIDENCED** (§ 3(b) defines consent; § 13 governs sensitive personal information; § 12 governs the general lawful bases). The current design relies on **"implicit consent"** — a guest uploads an RSVP profile photo and that upload is treated as consent to face-recognition auto-tagging (policy § 6.1: *"implicit consent — they uploaded the photo for this purpose"*).

Assessment. For **ordinary** PII, an implied/purpose-bundled consent may be defensible. For **sensitive biometric** data it is **likely insufficient**, for three reasons:

1. **Not specific.** Uploading a photo is a distinct act from consenting to have a **biometric template** computed and matched. Bundling the two means the biometric consent is not *specific* to that processing.
2. **Not clearly informed.** The guest is not necessarily told, at the moment of upload, that a 128-dim face vector will be generated, stored per-event, and used to auto-tag them.
3. **Not clearly evidenced.** "They uploaded a photo" is weak, contestable evidence of consent to biometric processing; RA 10173 expects consent to sensitive processing to be demonstrable as a discrete, recorded choice.

Recommendation (conservative path — the headline recommendation of this DPIA). Introduce an **explicit, separate, granular opt-in for face recognition**, distinct from photo upload:

- A dedicated toggle/consent string — e.g. *"Use face recognition to automatically find and tag me in this event's photos"* — presented **separately** from uploading a profile photo, defaulted **OFF**, and **logged with timestamp** (mirroring the `policy_acceptances` evidence pattern, ideally a purpose-specific `face_recognition_consent` record [TO CONFIRM]).
- Uploading a photo (for a display avatar / manual use) must remain possible **without** enabling face recognition — the two choices decoupled.
- Keep the full non-biometric path (QR + manual tagging) as the default so declining face recognition is costless.

- Re-consent, don't grandfather: existing enrolments captured under the implicit-consent model should be re-papared under the explicit opt-in before wider rollout [TO CONFIRM] with counsel.

Adopt this **unless PH counsel advises** that a narrower approach satisfies § 12–13 for this population. This is the single change that most reduces the residual risk of the whole feature (BV-1).

7. Residual-risk conclusion

With the controls in § 5 — above all **per-event scoping**, the **threshold ladder**, **≤ 5-min revocation**, **5-year deletion**, **face-blur opt-out**, and **encryption at rest** — most biometric risks reduce to **Low** (BV-2, BV-4, BV-5, BV-7, BV-9) or **Low–Med** (BV-3, BV-6).

However, overall residual risk is **CONDITIONAL** and cannot be declared **Low–Medium** until the **consent-standard fix lands**. Specifically, before or at wider rollout / scale:

1. **MUST — upgrade the consent standard (BV-1 / § 6)**: ship an **explicit, separate, evidenced face-recognition opt-in**, decoupled from photo upload, defaulted OFF, and logged. Re-consent existing enrolments. *This is the gating item.*
2. **MUST — resolve minor enrolment (BV-8)**: confirm whether the auto-tag path can enrol a minor guest today; if so, block it or gate it behind verified guardian consent. [TO CONFIRM]
3. **SHOULD — confirm engine location + key/image hygiene (BV-3)**: record the matching-engine host/location (and any sub-processor / cross-border transfer per policy § 10), confirm per-event key scoping, and confirm raw enrolment images are purged after the vector is derived. [TO CONFIRM]
4. **SHOULD — ensure paparazzi opt-out is offered before capture (BV-6)**, not only remediated after.

With items 1–2 done, residual risk across the feature is **Low–Medium**. Until then, the biometric processing should be treated as **counsel-first / not-cleared-for-wider-rollout**, consistent with the register R-01 status.

8. Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	_____	[TO CONFIRM date]
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	_____	[TO CONFIRM date]

Next review date: [TO CONFIRM date] (recommend: on adoption of the explicit face-recognition consent flow, at any material change to the vector schema / thresholds / retention, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The biometric processing remains counsel-first (register R-01): the explicit-consent upgrade (§ 6) and the minor-enrolment question (BV-8) must be resolved before wider rollout.

Compliance Facts Register — Setnayan

Date: 2026-07-05

Purpose: The single source for every [TO CONFIRM] value across the NPC pack. Owner-supplied facts + values I could derive (live DB / code / known infra). Finalize with the DPO (the owner/proprietor) + PH counsel, then thread into the pack (or maintain via the admin Compliance page — see note at end).

■ **The BIR TIN has been REDACTED from this file** (2026-07-05) — the sensitive government ID now lives only in the access-controlled **admin** → **Compliance** page (PR #2848), never in a repo. This file remains a working reference for the non-sensitive facts; still keep it out of any public repository.

1. Business identity — ■ supplied

Field	Value
PIC (legal)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE (sole proprietorship)
Proprietor	Indalecio Sacdalan Casasola II
DTI Business Name No.	8297508 (national · valid 25 Jun 2026 – 25 Jun 2031)
BIR TIN	[redacted — held by owner; entered in admin → Compliance] (sensitive government ID; deliberately not stored in this file / any repo)
Registered / principal address	76 Sampaguita Avenue, Quezon City (barangay + ZIP — add if NPC form requires)
NPC registration no.	(blank until filed)

2. DPO & team — ■ supplied

Field	Value
DPO	Indalecio Sacdalan Casasola II (the proprietor/PIC also serves as DPO) · iscasasolaii@gmail.com · already registered on the NPC DPO system (2026-07-07)
DPO employment basis	Internal — the proprietor/PIC also acts as DPO (2-person founding team). ■ PIC = DPO : NPC generally prefers a DPO with autonomy from the controller; for a 2-person sole proprietorship this is commonly accepted — counsel to confirm and, if kept, note a short independence rationale in the designation sheet (doc 03).
DPO phone / designation date	(to set — recommend stamping the date the manual is adopted)
Total headcount	2 — Indalecio S. Casasola II (proprietor + DPO) + Claire E. Buanhog (VP, co-founder)
Staff with personal-data access	Both (2 of 2)

3. Scale — ■ read from live DB (2026-07-05, early/pre-launch — will grow)

Data subjects	Count
Customer accounts (users)	19
Vendors (vendor_profiles)	50
Guests (guests)	332
Events	61
Active biometric face vectors (sensitive)	0

- **Sensitive-data holders today:** 0 biometric (no active face vectors); vendors submit government IDs during verification (a subset of the 50); guest **dietary_restrictions** may reveal health/religion (special category). Counts are small + pre-launch — but per the RoPA, **NPC registration is still advised** on the *risk-to-rights* + *not-occasional* grounds, independent of volume.

4. Breach response team — ■ currently the 2-person team

- No external DBRT members yet. Document the 2-person structure: **DPO = the proprietor (owner)** leads; **VP (Claire E. Buanhog)** supports. Add an external PH counsel liaison when engaged.
- 24/7 escalation contacts + DPO breach hotline: *(to set — even a single mobile + the DPO email suffices to start)*.

5. Sub-processors — ■ derived (jurisdictions from known infra)

Sub-processor	Role	Jurisdiction / hosting	Personal data?	DPA on file
Vercel	App hosting / edge	United States (global CDN)	Yes (in transit)	[confirm]
Supabase	Database (Postgres)	Singapore (ap-southeast-1)	Yes (PII)	[confirm]
Cloudflare R2	Media / object storage	APAC region	Yes (photos/vectors)	[confirm]
Resend (+ SendGrid fallback)	Email	United States	Yes (email addresses)	[confirm]
PostHog	Product analytics	US or EU cloud — <i>confirm which instance</i>	Minimal (no PII in events; opt-out)	[confirm]
Persona / Veriff / Onfido	Vendor ID verification	US / EU	Yes (gov ID — sensitive)	[confirm]
Anthropic / OpenAI	AI features	United States	Prompt content only	[confirm]

Suno	Music generation	United States	NO personal data — text-prompt / owned-catalogue only ⇒ not a personal-data sub-processor	n/a
Face matching	Biometric embedding + match	ON-DEVICE (face-api.js / MediaPipe, in-browser); vectors stored in Supabase (Singapore). No third-party face-matching service.	Yes (biometric, stored)	n/a (in-house)

6. Processing specifics — ■ derived

Question	Answer
Sensitive RSVP fields collected	dietary_restrictions + meal_preference (may reveal health / religious belief — special category). No standalone religion or health field.
Solely-automated decisions w/ legal/significant effect	YES — one, as of 2026-07-07: the Anti-Fraud engine (DPIA R-08 / ROPA DPS-12) can automatically suspend a vendor's public listing at a high fraud score (reversible). The irreversible wipe/ban is NOT automated (routed through the four-eyes admin gate). AI planning features remain assistive only. See 08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md §6 (RA 10173 §16(c)/§34) — a formal contest/appeal path is a flagged follow-up.
Maya Business (payment gateway)	Not active — dormant / V1.5 roadmap; no contract yet. Current payment is manual apply-then-pay (BDO/GCash).
Staff NDAs / privacy training / device policy	(to set — for a 2-person team, a short signed confidentiality + basic-hygiene note suffices; recommend adopting.)
DPIA / designation adoption dates	(to set on adoption.)

7. Remaining true unknowns (short list for owner/DPO + Claire/VP)

1. Barangay + ZIP for the address (if the NPC form requires granularity)
2. The DPO (owner) contact phone + the designation/adoption date (*email supplied: iscasasolaii@gmail.com*)
3. PostHog instance region (US vs EU cloud)
4. Which sub-processors have a signed DPA on file
5. Whether to adopt the light NDA / training / device-hygiene notes (recommended)

This register resolves the large majority of the pack's [TO CONFIRM] items. Recommended next step: move these facts into an access-controlled admin Compliance page (editable, admin-only, can export the NPC data sheet) — the

correct secure home for the TIN + DPO details, rather than a plaintext file.

Data Privacy Impact Assessment (DPIA) — Anti-Fraud & Trust Integrity (identity clustering · fraud detection · enforcement)

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted. · 2026-07-07

Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-08** (05_DPIA_Register_DRAFT_2026-07-05.md). It is **HIGH-risk** because it (a) **repurposes** already-collected personal data (device fingerprint, normalized home address, payment-sender identity) for a **new purpose** without the data subject's active choice, and (b) performs **automated decision-making with significant effects** — it can automatically hide a vendor's livelihood-bearing listing and, on human confirmation, permanently ban it.

■ **STATUS — this processing is LIVE IN PRODUCTION as of 2026-07-07, ahead of counsel sign-off (read first)**

The anti-fraud stack (repo PRs #2834/#2835/#2836/#2838/#2841 · migrations 20270516600000, 20270517644717, 20270518682623) was **shipped to production on 2026-07-07**. The engineering PRs each flagged **counsel review PENDING** for this RA 10173 processing; the **owner (PIC) elected to ship ahead of that review** to unblock the feature. **This DPIA is therefore a retroactive assessment** — it documents processing that is already occurring and identifies what must still be done (chiefly the **transparency/disclosure gap in §6**) to bring it fully into compliance. **Counsel review remains outstanding and is the gating adoption item.** Nothing in this DPIA should be read as confirming the processing was cleared before launch.

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com · registered (or registration in progress [TO CONFIRM]) with the NPC
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Anti-Fraud & Trust Integrity — identity clustering + vendor fraud detection/scoring + two-stage enforcement — register R-08
Governing policy	01_Contracts/Setnayan_Privacy_and_Security_Policy.md § 1.1 (identity/device/payment data collected), § 2 (purposes), § 3 (storage/RLS), § 4 (retention), § 10 (sub-processors/cross-border) — an Anti-Fraud amendment is REQUIRED and not yet drafted (see §6)

Feature specs	03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md §§ 3–6
Shipped code	migrations 20270516600000_identity_clusters_phase2, 20270517644717_fraud_signals_detection_engine, 20270518682623_fraud_enforcement_state_and_audit; apps/web/lib/fraud-detection*.ts; admin surface /admin/fraud
Risk level (inherent)	HIGH — repurposed personal data + involuntary profiling + automated decisions with significant effects
DPIA status	DRAFT — pending DPO adoption + PH counsel review; processing is already live (see status banner)
Version / date	2026-07-07

1. Description of the processing

1.1 What the processing is

Three layered, service-internal mechanisms that protect marketplace trust signals (reviews, booking counts, badges) from manipulation:

1. **Identity clustering** — links multiple user accounts that are probably the *same person or household* by **shared strong signals**: the same **device fingerprint**, the same **normalized home address**, or the same **payment-sender identity**. Each connected group is assigned an opaque `cluster_id`.
2. **Trust-stat de-duplication** — vendor review counts, ratings, and completed-booking counts are counted **per cluster, not per account**, and **arm's-length-excluded** (a review/booking from someone in the vendor owner's or team's own cluster does not count). This is what makes fake-account rings ineffective.
3. **Fraud detection + two-stage enforcement** — per-vendor anomaly **signals** (score 0–100) are computed and stored; a high aggregate score can **auto-suspend** a vendor (reversible), and — only on a second admin's confirmation via the four-eyes gate — a vendor can be **wiped + permanently banned** (irreversible).

1.2 Why it is processed (purpose)

Fraud prevention and marketplace integrity — to stop vendors from inflating their reviews, ratings, badges, and booking counts with sockpuppet accounts (fake couples on shared devices/addresses/payment sources), and to detect and act on anomalous trust-manipulation patterns. The purpose protects **couples** (who rely on honest trust signals to choose vendors) and **honest vendors** (who are otherwise out-competed by fabricated reputations).

1.3 Lawful basis (preliminary — to be confirmed by counsel)

Legitimate interest — RA 10173 § 12(f): fraud prevention is a recognized legitimate interest of the PIC and of honest data subjects. This basis requires a documented **legitimate-interest balancing** (necessity ↔ data-subject impact) and **transparency** (the processing must be disclosed). **Neither the balancing test nor the disclosure yet exists — this is the headline finding (§6).** [TO CONFIRM] — DPO/counsel to confirm § 12(f) as the basis for each data category and the automated-decision provisions of § 16(c) / § 34.

1.4 A secondary use of already-collected data — NO new collection

Critically, this processing **collects no new personal data**. It **repurposes** data already collected and recorded for other purposes:

- **Device fingerprint** — `user_devices.device_hash` (already collected for session/security).
- **Normalized home address** — `users.address_normalized` (already collected at account/profile).
- **Payment-sender identity** — `payments.reference_number` joined to the paying user (already collected for apply-then-pay reconciliation, DPS-08).

Because it is a **new purpose over old data**, the compliance question is one of **purpose-compatibility + disclosure**, not new consent for collection. Under RA 10173 a further, compatible processing purpose is permissible on a lawful basis, **but it must be disclosed** — which it currently is not (§6).

1.5 Data subjects

- **Couples / customers / guests** — whose device/address/payment signals are clustered to detect review/booking rings. **They never see cluster membership** (service-role only). This is the more novel, involuntary population.
- **Vendors** — whose trust stats are de-duplicated and who are **scored, and potentially auto-suspended or banned**. This is the population subject to **automated decisions with significant effects**.

1.6 Data categories processed

- **Identity-link signals (input)**: device fingerprint hash, normalized home address, payment-sender reference. (Personal information; **not** SPI under § 3(l).)
- **Derived — identity cluster membership**: an **inference** that two or more accounts are the same person/household. (A new derived personal datum about the linked individuals.)
- **Derived — vendor fraud signals/scores**: per-vendor anomaly signals (`ring`, `velocity`, `graph_isolation`, `import_spike`, `rating_shape`), each with a 0–100 score and a **non-PII** evidence JSONB (counts, ratios, opaque cluster labels, booleans — **no names, no addresses, no raw identifiers**).
- **Enforcement state**: `fraud_suspended_at` / `fraud_banned_at` / `fraud_tombstoned` on the vendor; `voided_by_fraud` flags on the vendor's reviews/events; an append-only `fraud_enforcement_audit` row per action.
- **Intentionally NOT processed: IP address** — no core identity table captures an IP, and IP-capture infrastructure was **deliberately not built** (deferred to a future "Phase 2.1"). This is a data-minimization choice.

1.7 Systems, storage, and retention

- **Database of record**: Supabase Postgres (**Singapore**). `identity_clusters` + `user_identity_signals` (views/matviews), `fraud_signals` + `vendor_fraud_scores`, enforcement columns + `fraud_enforcement_audit`.
- **Access control: service-role / admin ONLY**. Every object carries `REVOKE ALL FROM anon, authenticated` and/or `is_admin()` RLS at `CREATE TABLE` time — **couples and vendors can never read cluster membership, fraud signals, or scores**.
- **Cross-border**: SG (Supabase) only for this processing. No US/third-party AI sub-processor is involved (the clustering + scoring are plain SQL/TypeScript in-house).
- **Retention**: `identity_clusters` / `vendor_fraud_scores` are **recomputed matviews** (no independent history). `fraud_signals` + `fraud_enforcement_audit` **persist** — **a specific retention rule for these is not yet defined [TO CONFIRM]** (see AF-8). Underlying signal inputs follow their source systems' retention (device/address = account retention; payment = 5-year tax retention, DPS-08).

2. Necessity & proportionality assessment

2.1 Is the processing *necessary* for the purpose?

Marketplace trust is the product's core promise; fabricated reviews/bookings directly harm couples and honest vendors. **Non-identity-based** anti-fraud (e.g. manual moderation) does not scale and cannot see cross-account rings. Identity clustering is the mechanism that actually neutralizes sockpuppet rings, and per-cluster de-duplication is the minimal way to make fake accounts ineffective without deleting anyone. So the clustering + de-duplication layer is **necessary and well-targeted**.

Automated **scoring** is necessary to triage at scale; automated **suspension** is a proportionality choice (see §2.2) — justified only because it is **reversible** and set at a **high-confidence threshold**.

2.2 Proportionality — is it minimized, and are the effects proportionate?

The design minimizes structurally:

- **No new data collected** — secondary use of existing signals only (§1.4).
- **IP deliberately excluded** — the most privacy-invasive identity signal was not built (§1.6).
- **Service-role-only** — the inferences are never exposed to any data subject or other user; they exist solely to correct trust math and feed the admin queue.
- **Non-PII evidence** — the stored fraud evidence carries counts/ratios/opaque labels, not identities.
- **The irreversible action is NOT automated** — only the **reversible** auto-suspend is automated, and only at a **high aggregate score** (≥ 90), strictly above the advisory band. The **wipe + permanent ban** requires a **second admin's confirmation** through the existing four-eyes gate — a human, accountable, logged decision, never the machine's.
- **Appeal path** — an enforcement action opens a help-center appeal ticket stub, giving the vendor a route to contest.

Conclusion. The processing can be proportionate **conditional on §6** — i.e. once (a) it is **disclosed** to data subjects and (b) a **legitimate-interest balancing** is documented and counsel-reviewed. The automated-suspension effect is proportionate **because** it is reversible and human-reversible in one action; the irreversible effect is proportionate **because** it is never automated.

3. Consultation

- **DPO:** prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The transparency finding (§6), the lawful-basis mapping (§1.3), the retention gap (AF-8), and the automated-decision rights (§6 / AF-5) are referred to the DPO and PH counsel.
 - **Data subjects: not yet consulted or notified** for this specific processing — there is currently **no notice** that device/address/payment data is used to cluster identities for fraud prevention, and no notice to vendors that they may be automatically scored/suspended. Closing that is the §6 recommendation.
 - **External counsel / NPC: required** — register R-08 is counsel-first, and the processing shipped ahead of that review (status banner). Counsel to confirm the § 12(f) basis, the § 16(c)/§ 34 automated-decision provisions, the retention rule, and whether an NPC consultation is advisable given the automated-enforcement effect.
-

4. Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§5).

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
AF-1	Undisclosed repurposing — device/address/payment data collected for other purposes is used to cluster identities for fraud prevention without notice to the data subject (transparency failure under § 12(f) + the § 16 right to be informed)	High	High	High	Service-role-only (never surfaced); no new collection; purpose-limited to fraud prevention	Med-High — NOT resolved by current controls. Reduces to Low only after the Privacy Policy discloses the processing + the right to object (§6). Headline gap.
AF-2	Wrongful automated suspension of a legitimate vendor (false positive hides their livelihood-bearing listing)	Med	High	High	Reversible auto-suspend; high threshold (score ≥ 90, above the advisory 60); admin Dismiss / Un-suspend in one action; fail-soft scoring	Low-Med
AF-3	Wrongful irreversible ban — a vendor is wiped/banned and reviews/events voided in error	Low	High	High	Never automated — routed through the two-admin (four-eyes) gate ; typed business-name confirmation; append-only <code>fraud_enforcement_audit</code> ; help-center appeal ticket opened	Low-Med

AF-4	Cluster mis-linkage — unrelated people linked as one identity (shared family PC, shared address, one person paying for another) → a false "same identity" inference	Med	Med	Med	Used only to de-dup trust stats + as one fraud-signal input, never surfaced to users; enforcement needs corroborating anomaly signals, not cluster membership alone; bounded (≤ 64-hop) cycle-guarded closure	Low–Med
AF-5	Data-subject rights over automated processing — a vendor cannot access/understand/contest an automated decision (RA 10173 § 16(c) right to object; § 34 rights re automated processing)	Med	High	Med–High	Appeal-ticket stub on enforcement; irreversible step is human-decided; audit trail records rationale	Med — a formal access/object/contest path for automated scoring is not yet documented (see §6)
AF-6	Breach of the identity-cluster / fraud store — exfiltration of who-is-linked-to-whom or who-is-flagged	Low	Med–High	Med	Service-role/admin ONLY (REVOKE ALL FROM anon, authenticated, is_admin()) RLS at CREATE); non-PII evidence; SG-only (no third-party processor); AES-256; TLS 1.3	Low
AF-7	Function creep — cluster/fraud data reused for marketing, ranking, or sold/shared	Low	High	Med	Purpose-limited by design + policy § 2.3 (no sale/cross-vendor sharing/advertising); service-role-only	Low — pending an explicit policy lock naming this processing

AF-8	Over-retention of fraud signals — <code>fraud_signals</code> / <code>fraud_enforcement_audit</code> kept longer than necessary	Med	Med	Med	Matviews (<code>identity_clusters</code> , <code>vendor_fraud_scores</code>) recomputed, no history; enforcement audit is intentionally durable	Med — no explicit scoring/aging rule for <code>fraud_signals</code> yet [TO CONFIRM] (audit trail retention should be justified against BIR/dispute needs)
------	---	-----	-----	------------	---	---

5. Controls already built

Load-bearing for the residual ratings above; all verified against the shipped migrations/code:

- **Service-role / admin ONLY** — `identity_clusters`, `user_identity_signals`, `fraud_signals`, `vendor_fraud_scores`, and the enforcement/audit objects carry REVOKE ALL FROM anon, authenticated and/or `is_admin()` RLS at **CREATE time**. No data subject can read them.
- **No new data collection** — secondary use of `user_devices.device_hash`, `users.address_normalized`, `payments.reference_number` only.
- **IP deliberately not captured** — the most invasive identity signal was left unbuilt (data minimization).
- **Non-PII evidence** — `fraud_signals.evidence` holds counts/ratios/opaque cluster labels/booleans, not identities.
- **Automated action is the reversible one only** — auto-suspend at aggregate score ≥ 90 (above the advisory 60); it hides the listing + freezes badges but **destroys nothing** and reverses in one admin action.
- **Irreversible action is human + four-eyes** — wipe + permanent ban routes through the existing **two-admin approval gate** (`admin_approval_requests`, new `approve_fraud_wipe_ban` action type); a *different* admin confirms; never automated.
- **Append-only audit** — every enforcement action writes a `fraud_enforcement_audit` row (actor, rationale, evidence snapshot).
- **Appeal route** — enforcement opens a help-center appeal ticket stub.
- **Defense-in-depth freeze** — a fraud-frozen vendor is excluded from the marketplace query, `/v/[slug]`, `api/v1/vendors`, and the Spotlight-Award candidate pool.
- **Bounded computation** — the cluster closure is a cycle-guarded, ≤ 64 -hop recursive CTE (to be promoted to a nightly union-find job at scale).

6. KEY FINDING — the transparency & automated-decision gap (headline)

Finding. The processing is lawful in principle on a **legitimate-interest (§ 12(f))** basis, but two accountability requirements of that basis are **not yet met**, and the processing is **already live** (status banner):

1. **No disclosure / notice.** Neither couples nor vendors are told that (a) their **device fingerprint, home address, and payment-sender identity** are used to **cluster identities for fraud prevention**, nor that (b) vendors may be **automatically scored and suspended**. RA 10173's § 16 right-to-be-informed and the transparency limb of § 12(f) require this to be disclosed. **This is the single most important gap.**

2. **No documented legitimate-interest balancing (LIA) and no formal automated-decision rights path.** § 12(f) requires the PIC's interest to be weighed against data-subject rights and freedoms, recorded. And because auto-suspension is a decision producing a **significant effect** on a vendor, the § 16(c) right to object and § 34 provisions on automated processing should be reflected in a documented **contest/appeal** path (the ticket stub exists; the formal process does not).

Recommendation (the headline recommendation of this DPIA).

- **MUST — publish an Anti-Fraud disclosure** in the Privacy Policy (a new amendment, mirroring the Person-Graph amendment pattern): state plainly that device/address/payment data may be used to detect and prevent fraudulent trust manipulation, that vendors may be subject to automated integrity checks and (reversible) suspension with a human-reviewed, appealable path to any permanent action, and the legitimate-interest basis + how to object. Present it to couples and vendors.
- **MUST — record a legitimate-interest balancing test (LIA)** for the clustering + scoring, and a **formal vendor contest/appeal procedure** for automated suspensions (elevate the ticket stub to a documented § 16(c)/§ 34 path).
- **MUST — obtain the outstanding counsel review** (register R-08 is counsel-first; the processing shipped ahead of it — status banner). Counsel to confirm § 12(f) mapping, the automated-decision provisions, and whether an NPC consultation is advisable.
- **SHOULD — define a retention rule** for `fraud_signals` and justify `fraud_enforcement_audit` retention (AF-8).

Until the disclosure (item 1) lands, the residual risk of AF-1 stays **Med–High** and the processing, while operational, is **not fully compliant** on the transparency limb.

7. Residual-risk conclusion

With the controls in §5 — above all **service-role-only access**, **no new collection**, **non-PII evidence**, **reversible-only automation at a high threshold**, and the **four-eyes gate on the one irreversible action** — most risks reduce to **Low** (AF-6, AF-7) or **Low–Med** (AF-2, AF-3, AF-4).

However, overall residual risk is CONDITIONAL and cannot be declared Low–Medium until the §6 transparency items land, and the processing is currently **live ahead of counsel review**. Before this can be treated as adopted/cleared:

1. **MUST — publish the Anti-Fraud Privacy Policy disclosure + notice** (AF-1 / §6). *Gating item.*
2. **MUST — record the legitimate-interest balancing (LIA) + a formal automated-decision contest path** (AF-5 / §6).
3. **MUST — complete the outstanding PH counsel review** (R-08 counsel-first).
4. **SHOULD — set a retention rule for `fraud_signals` + justify audit retention** (AF-8).

With items 1–3 done, residual risk across the processing is Low–Medium. Until then it should be treated as **operational-but-not-yet-cleared / counsel-first**, consistent with register R-08. The design itself is sound; the gap is **paperwork + disclosure**, not architecture.

8. Sign-off

Role	Name	Signature	Date
------	------	-----------	------

Data Protection Officer	Indalecio Sacdalan Casasola II	_____	[TO CONFIRM date]
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	_____	[TO CONFIRM date]

Next review date: [TO CONFIRM date] (recommend: on publication of the Anti-Fraud Privacy Policy disclosure, at any material change to the clustering signals / scoring thresholds / enforcement model, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The processing is live in production as of 2026-07-07 ahead of counsel sign-off (owner-elected); the transparency/disclosure upgrade (§6) and the outstanding counsel review are the gating items to bring it fully into compliance.

Setnayan — Data Retention Schedule

Status: DRAFT — [PENDING COUNSEL]. Retention periods below are reasoned from the standard PH statutes (RA 10173, NIRC/BIR, Civil Code). They are **not legal advice** and must be ratified by external counsel before launch. **DPO = the owner** (Indalecio S. Casasola II) per `[[dpo-designation-owner]]`; external counsel = TBD.

Created 2026-07-11. This is the canonical answer to "how long do we keep user data, and until when *can* we keep it?" — supersedes scattered "5-year" mentions in individual iteration specs.

1. Governing principles

Retention is bounded on **both** ends, and the two bounds come from different laws pulling in opposite directions:

Bound	Source	Effect
Maximum (delete <i>by</i>)	RA 10173 (Data Privacy Act) — storage-limitation principle	Personal data may be kept only as long as necessary for its purpose, then must be securely disposed of. Indefinite retention of personal data is itself a violation and a breach-surface liability. "Keep everything forever" is not an option for personal data.
Minimum (cannot delete <i>before</i>)	NIRC / BIR RR 17-2013 ; Civil Code Art. 1144	Financial/tax records must be kept 10 years ; a written contract is actionable for 10 years , so contract records must survive that dispute window. These override an earlier RA 10173 erasure for the specific records they cover.

Design consequence: a chat thread and the payment attached to it are **different retention classes**. You cannot anchor everything to one "delete at N years" switch — you would either illegally delete a tax record or needlessly hoard chat. Retention is **per data class**, below.

2. Retention schedule (by data class)

#	Data class	Iteration(s)	Retention anchor	Keep for	Legal basis	Disposal
1	Vendor↔couple chat (chat_threads, chat_messages)	0019	event_date	5 years	RA 10173 necessity + normal dispute window	Hard-delete thread + messages
2	Media — Paptic photos/video, gallery, reels (R2)	0012, 0009, 0024	event_date	5 years (hot 90 d → cold → purge)	RA 10173; PH photographer norm	R2 lifecycle expiry

3	Payments / receipts / Official Receipts	0026, 0034	payment date	10 years — <i>legal floor, cannot delete early</i>	BIR RR 17-2013	Purge at 10 y
4	Contracts + e-signatures	0032	contract execution date	10 years	Civil Code Art. 1144 prescription	Purge at 10 y
5	Account / profile PII (users, settings)	0025	account close / deletion request	Life of account + 30–90 day tail , then purge	RA 10173 storage limitation	Soft-delete → hard-delete after tail
6	Face-recognition vectors (face_enrollments)	0012	event_date	Per-event only; revocable on request; purge with media (≤5 y)	RA 10173 sensitive data; per-event-scoped lock	Delete on revoke or at media purge
7	Marketing consent / comms prefs	0025, 0028	last consent change	Life of account + audit tail	RA 10173 / CAN-SPAM proof-of-consent	Purge with account
8	Support tickets / help-center	0029	ticket close	2 years	Operational necessity	Purge at 2 y
9	Observability / logs (Sentry, PostHog)	0035	event timestamp	Provider default (≤ 90 days); no PII in logs	RA 10173 data-minimization	Provider TTL
10	Device-fingerprint hashes (user_devices, device_hash) — fraud prevention	Fake-Inquiry Protection (device_hash)	last_seen_at	Life of account; rolling-prune device rows unused > 24 mo (proposed)	RA 10173 §12(f) legitimate interest (fraud prevention); pseudonymous, non-sensitive	Purge with account (class 5 tail) or on rolling prune

The two clocks, stated plainly

- **Default = 5 years** for the *experience* data (chat + media), anchored to `event_date` so a wedding's whole record ages together.
- **Legal-hold floor = 10 years** for anything touching **money or a contract** — flagged and **exempt** from the 5-year sweep.

3. Right-to-erasure interaction (RA 10173 §16)

A user's erasure/account-deletion request (iteration 0025) deletes their personal data **now, except** records under a legal-hold floor (classes 3 & 4 — payments, contracts), which are **retained under the legal-obligation basis** and disclosed as such in the privacy policy.

This carve-out is standard and defensible: "We honor deletion requests except where law requires us to retain financial and contractual records, which we keep for the statutory period and then dispose of."

4. Implementation reality (as of 2026-07-11)

Audited against shipped code — **the retention plumbing is greenfield**; almost none of this is enforced yet:

- **Chat** (`chat_threads` / `chat_messages`): text-only, append-only, no attachments. **No** `archived_at` / retention / soft-delete columns. `chat_threads.updated_at` already tracks last activity (free `last_message_at`).
- **R2 lifecycle: NOT configured** — hot→cold tiering + expiry exist only as prose in `OWNER_ACTIONS.md` and marketing copy. No `wrangler.toml`/Terraform in the repo. **This is the real space program** (media = gigabytes; chat = megabytes).
- **No cleanup cron** touches chat/media. House style deliberately avoids `pg_cron` (uses Vercel cron + on-access sweeps).
- **■ Compliance gap**: account hard-delete (`admin/users/actions.ts` → `deleteUser`) sets chat user-FKs to NULL but **leaves message bodies (the couple's PII) in `chat_messages` indefinitely** — threads only cascade on *event* delete, and events are never deleted. Fixing this is part of enforcing class 1 & 5.

Build order to enforce this schedule

1. **Archive (UX, zero deletion)** — add `archived_at` to `chat_thread_reads` (per-user); inbox filter `archived_at IS NULL OR chat_threads.updated_at > archived_at` (Viber-style: a new message un-archives). Ships safely on its own.
2. **R2 lifecycle** — actually configure bucket rules for class 2 (the gigabyte win).
3. **Retention sweep** — weekly Vercel cron `/api/cron/retention-sweep`: hard-delete class 1/2 at anchor + 5 y; **skip** any thread/record tied to an active legal hold (class 3/4). Fix the account-deletion residue in the same job.

5. Open items for counsel [PENDING COUNSEL]

1. Confirm **BIR retention = 10 years** for in-app SKU payments + Official Receipts (RR 17-2013) and the exact record scope.
2. Confirm **contract retention** period + whether e-signature audit trails (RA 8792) extend it beyond 10 years.
3. Ratify the **5-year default** for chat + media as "necessary" under RA 10173 §11(e).
4. Approve the **erasure carve-out** wording (§3) for the privacy policy.
5. Confirm **face-vector** treatment as sensitive personal information and the per-event purge rule.
6. Sign off on **device-fingerprint hashes** (class 10) — legal basis (legitimate interest vs consent), notice wording, and the 24-month rolling-prune period. See the dedicated one-pager `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md`.

Related: `[[dpo-designation-owner]] · 0025_profile_settings/ · 0026_bir_tax_compliance/ · 0032_contract_intelligence/ · 0019_communications/ · Pricing.md § 2.1 (media storage/longevity ladder)`.

Privacy Reconciliation — Updated Home & New Data Flows vs. the Privacy Corpus

Date: 2026-07-13 · **Type:** compliance deep-dive + gap register · **Status:** findings for owner/DPO/counsel — nothing silently changed

Trigger: owner — *"do a deep dive and track. most specially we updated our home."*

Method: 4-front audit — (1) redesigned couple **Home/Event Overview** data flows (worktree feat/overview-council-redesign @ 4eb39a329, PR #3188), (2) new 2026-07-12 capture features + SPI/minor + build-state (grounded in origin/main migrations), (3) the live setnayan.com/privacy notice content, (4) the 9-doc privacy corpus for canonicity + conflicts. Load-bearing facts re-verified directly against origin/main before writing.

Headline. Setnayan is **collecting sensitive personal information and minors' data in production, live, with disclosure gaps**. Profile **religion + civil status + gender** capture is live with no flag; the **dependents** table (minors' birth-date + religion + sex + godparent third-party emails) is recorded as flag-ON in prod (DECISION_LOG 2026-07-13); the onboarding **events.signature_details** path collects a child's DOB/gender and a pregnancy due-date with **no flag and no consent stamp**; and the couple **Home** now renders explicit religious-rite data. Meanwhile the **live privacy notice (last updated 2026-07-04)** mentions **none** of faith, minors, device-fingerprint, or e-gift handles — and **affirmatively denies collecting biometrics** while a biometric-enrollment feature is built. The freshest master dossier (2026-07-12) is the **narrowest** SPI declaration in the corpus and is **uncommitted**.

A. LIVE-NOW gaps — SPI / minors / financial PI collected in prod, undisclosed (SEV-1)

Ranked by exposure. "Live" = shipped on origin/main with capture reachable in production.

#	Data collected	Where	RA 10173 class	Build state (verified)	Disclosed anywhere?
1	Religion + civil status + gender (self)	users.religion / civil_status / sex (+ *_consent_at)	■ SPI §3(l) — religion & marital status; sex sensitive-adjacent	LIVE, no flag, consent-stamped. profile/actions.b writes directly (verified origin/main). Gender added today (PR #3209).	■ Notice/dossier §5 list only biometrics as SPI

2	Dependents — minor's <code>birth_date</code> + sex + religion; godparent name + email (3rd party); godchild-birthday emails to that 3rd party	dependents, godparents	■ Minor + SPI + third-party PII	Shipped; flag NEXT_PUBLIC_DEPENDENT default OFF in code, but DECISION_LOG 2026-07-13 records owner set it =1 in prod ("long done"). If so → collecting now; godchild emails go live next deploy. Household RLS shares a child's record with the spouse and persists after annulment/separation (owner rule B6).	■ Zero coverage. DEPENDENT_PEOPLE amendment (07-05) still says person-graph is "adults-only..." <i>minors not processed</i> — now contradicted
3	Onboarding specialty fields — christening <code>child_birth_date</code> + <code>child_gender</code>; gender-reveal pregnancy due_date; <code>ceremony_rite/rite_type</code> (religion); birthday <code>celebrant_age</code>	events.signature JSONB	■ Minor's sex + health-adjacent (pregnancy) + religion	LIVE, NO flag, NO consent stamp. With all 14 event types enabled (#3127), a christening/gender-reveal create-flow accepts these today. Gender-reveal <code>due_date</code> contradicts the council's own Q3 "defer due-date capture until counsel clears."	■ Not disclosed; collectable outside the counsel gate that governs the parallel dependents table
4	Explicit religious-rite data on the couple HOME — Muslim nikah overlay (<code>mahr_description</code> free-text dower, <code>gender_separation</code>, wali/witness/imam guest roles), Chinese/Tsinoy tea-ceremony tile	events.*, guests.role, surfaced by Overview overlays	■ SPI §3(l) religion	LIVE — rendered on /dashboard/[eventid] Home	■ Notice never mentions ceremony as a data category

5	Biometric face enrollment — selfie + mandatory biometric-consent flow; <code>face_vector</code> column exists	<code>guest_face_enrollment</code>	■ NOT §13 biometric	Built. Code comment: vector is DORMANT (image-only enrollment until an embedder/model is live) → selfies + consent captured now, vectors not yet stored.	■ Notice affirmatively DENIES it — lists "Face biometrics or any other biometric data" under " What we do not collect. " Denial is currently technically-true-for-vectors but false the moment the model ships, and the consent/table already exist
6	Pabuya e-gift handles — couple's own gcash/maya/bank/paypal handle + <code>account_name</code> + receiving-QR image	<code>event_egift_method</code>	■ Financial PI (not §13 SPI); display-only by design (no amount/ledger column)	Table LIVE; public guest route <code>PABUYA_PUBLIC_ROUTE_ENABLED</code> in prod per <code>DECISION_LOG</code> 2026-07-13	■ Zero mentions in all 9 privacy notices — 1 fully-undocumented processing activity

Data-minimization note (home): the Overview server component loads **full guest rows** — email, mobile, `dietary_restrictions/meal_preference` (health-adjacent), and `photo_consent/faceblock_enabled/face_recognition_excluded` (biometric-adjacent) — into memory even though only aggregate counts render. Co-host/invitee **email addresses are displayed** in the Hosts card, read via the RLS-bypassing admin client. Not a disclosure gap, but a minimization item worth a pass.

What bounds the exposure (good news): on the *home surface specifically*, dependents/minors' Year-view data is **flag-off and its commits are not in the redesign branch** (year-view code asserts "zero PII, no birthdates"), and **no e-gift handle is surfaced on any home surface**. So gaps #2 and #6 are live in their own routes, not additionally leaked onto Home.

B. Doc-corpus conflicts & staleness to reconcile (SEV-2/3)

The corpus is **four layers, no single canonical doc**. Deepest/most complete = the **tracked NPC Compliance/ pack** (11-system RoPA + DPIAs). The shiny **NPC Privacy Compliance Dossier 2026-07-12.md** is the freshest executive summary but the **narrowest** SPI declaration — treat it as a summary annex, not the filing backbone.

- **Device-fingerprint "is it live?" — direct conflict.** New dossier §4 + `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12` say flag-OFF / collects nothing. But `01_Contracts/Anti_Fraud_Privacy_Policy_Amendment_DRAFT_2026-07-08` B.1 says "*we analyse signals we already hold: your device fingerprint... already active (shipped 2026-07-07)*" and DPO Designation B.5 lists it "live 2026-07-07." **Reconcile before either publishes.**
- **Dossier's PIA claims the fingerprint disclosure was "published in the public privacy notice 2026-07-12."** The live notice is dated **2026-07-04** and contains **no** device-fingerprint language. The claim is unsupported by the page.
- **SPI under-count in the new dossier.** §5 names only biometric vectors. The NPC pack treats **vendor gov-ID + liveness + AMLC/PEP sanctions** as the SPI categories that *trigger NPC registration* — the new dossier drops the entire vendor-verification surface. Filing the dossier as-is would under-declare.

- **DPO contact split.** New dossier → dpo@setnayan.com; every other doc → iscasasolaii@gmail.com. Two published DPO addresses. (DPO **identity** is consistent everywhere: the proprietor, Indalecio S. Casasola II — no doc names "Claire.")
- **Response-SLA split.** Dossier says **15 business days**; Privacy Policy §9 + DPO Designation say **7 business days**.
- **Retention — binding policy is stale.** Setnayan_Privacy_and_Security_Policy.md §4 has **no 10-year floor** (5y/7y model) and contradicts the newer Data_Retention_Schedule_2026-07-11 (10-yr floor on payments/OR + contracts). The schedule's own §4 flags a **live gap**: account hard-delete **leaves chat PII behind**. Vendor-verification retention (90d hot → 7y cold) exists in the policy but is **absent from both the new schedule and the dossier ROPA**.
- **Subprocessor list omissions.** /privacy names **Persona + Anthropic** as cross-border recipients but leaves them **out of the Subprocessors table**; **Suno** (music generation) is missing from policy §10.
- **Cookie consent is localStorage-only** (setnayan-cookie-consent-v1) — no server-side consent-events log, which weakens RA 10173 proof-of-consent retention.
- **Stale one-pager.** Setnayan_AI_Data_Use_DPO_Review_2026-06-29 frames the AI as a *paid* assistant learning from *browsing behavior*; current direction is **deterministic + free** — the behavioral-personalization framing reads stale.
- **Durability risk.** The three newest/most-relied-on docs — **dossier (07-12), retention schedule (07-11), fingerprint one-pager (07-12)** — are **UNTRACKED (uncommitted)**, i.e. the current "canonical" master + retention authority are the least-durable files in the set.

C. Owner / DPO / counsel decision queue (NOT actioned here — surfaced per corpus rules)

These are load-bearing and/or legal; I did not change the notice, the dossier, or any flag.

1. **Confirm the prod flag reality.** DECISION_LOG asserts NEXT_PUBLIC_DEPENDENT_PEOPLE=1 and PABUYA_PUBLIC_ROUTE_ENABLED=1 are ON in Vercel prod (unverifiable from the repo). If ON, the dossier must add a **live SPI+minors** processing activity (dependents) and a **financial-PI** activity (e-gift), incl. the household RLS spread + post-dissolution retention.
 2. **Close the signature_details SPI hole.** Either gate the christening child_birth_date/child_gender, gender-reveal due_date, and ceremony_rite fields the same way the dependents table is gated, or attach equivalent consent copy + retention. The un-flagged due-date field directly contradicts the council's own defer recommendation.
 3. **Fix the biometric denial.** The notice's "we do not collect biometrics" is a landmine given guest_face_enrollments + consent flow exist and vectors go live when the embedder ships. Rewrite to "optional, opt-in, per-event, currently image-only" rather than a flat denial.
 4. **Publish the faith / minors / e-gift / device-fingerprint disclosures** in the public notice + add ROPA rows. These are the four categories the notice omits.
 5. **Reconcile the corpus conflicts** in §B: pick one DPO email + one SLA; add the 10-yr floor + vendor-verification class to the binding policy; add Persona/Anthropic/Suno to the subprocessor list; resolve the device-fingerprint live/off contradiction; decide on a server-side consent log.
 6. **External counsel sign-off** for the §3(I)/minors/third-party-notify cluster and the BSP-OPS e-gift question — the specs flagged *external* review as required; the owner-is-DPO marking resolves the internal step only.
-

D. What was tracked in this pass

- This document (the gap register).
- `DECISION_LOG.md` row (2026-07-13).
- Memory: `project_setnayan_privacy_reconciliation.md` + index pointer.
- The three previously-untracked privacy docs (dossier 07-12, retention schedule 07-11, device-fingerprint one-pager 07-12) committed into git history alongside this, so the canonical set is durable.

Not done (needs owner/DPO/counsel): editing the live `setnayan.com/privacy` notice (code-repo change + legal disclosure), or flipping any feature flag.

Correction — 2026-07-13: "dependents" is generic, not a minors registry

Owner: *a dependent "can be a dog, a cat, or anyone — there is no specification that it needs to be a child."* This audit (§A row 2, §C, and the "minors' data" framing throughout) over-characterized the dependents table as a minors registry. It is now a generic **"someone (or something) you care for"** list with a `dependent_kind` (person / pet / other) — app PR #3219. Only `kind=person` may carry a birth date / religion / sex under the age fence, and only there does minors' SPI arise (as a **conditional sub-case**, when the adult enters a child). Pets/other carry no sensitive data. Treat every "dependents = minors' data" statement in §A/§C as reframed by this note; the dossier §3/§5 and binding policy were updated to match.

Correction — 2026-07-13: the live notice was better than first reported

When the `/privacy` notice was edited (PR #3215), reading `origin/main` directly revealed the earlier extraction (agent, §A row 5 + §B) was from a **stale local checkout**: the deployed notice **already** carried a proper opt-in **Biometric** section (no "denies biometrics" line) and a **Device identifier (fraud prevention)** section. So gaps #5 (biometric denial) and the "notice omits device fingerprint" claim were **not real on the live site**. The genuine notice gaps were narrower — faith/family/honoree/e-gift + Anthropic/Suno — and those are what PR #3215 added. The dossier §5/§4/§11 were corrected to match. Treat §A row 5 and the §B "device-fingerprint disclosure" bullet as superseded by this note.

Update — 2026-07-13: dossier upgraded to a submittable v2.0

Owner: *"edit it and update so that will be the document we can submit NPC."*

`NPC_Privacy_Compliance_Dossier_2026-07-12.md` was rewritten to **v2.0** and the `.docx` mirror regenerated. It now closes the **document-side** gaps from §A/§B: the ROPA (§3) covers all 18 processing activities incl. self-profile religion/civil/gender, the dependents/godparents family graph, event honoree/`signature_details` data, e-gift handles, and vendor-verification identity; the SPI declaration (§5) enumerates every sensitive category (was biometric-only); the subprocessor list (§7) adds Persona/TikTok/Suno; retention aligns to the 07-11 schedule's statutory floors. Owner decisions applied: **device fingerprint = OFF/dormant**; **minors' signature_details SPI = documented as-is**; DPO contact `dpo@setnayan.com` + 15-day SLA (matching the live surfaces). A consolidated **§11 "Open items before filing"** carries the residue: external counsel review (the final gate — this is a DPO draft, not legal advice), the **public /privacy notice** reconciliation (add faith/minors/e-gift/fingerprint disclosures + fix the biometric denial), and the older-corpus alignment (gmail→dpo@, 7→15-day SLA, 10-yr floor + vendor class + Persona/TikTok/Suno into the binding policy). **Still not done — needs owner/counsel:** the notice edit and external legal sign-off.

Device-Fingerprint Capture — One-Pager for DPO Review

For: the Setnayan DPO (the owner, Indalecio S. Casasola II — per `[[dpo-designation-owner]]`), NPC-registered.

Ask: review + sign off on the legal basis, notice wording, and retention below before the **device-fingerprint capture** (fake-inquiry protection · Phase E) is switched on. The design is deliberately minimal and privacy-preserving — this should be a **sign-off, not a redesign**.

Date: 2026-07-12. **Law:** RA 10173 (Data Privacy Act) + NPC issuances.

Companion: `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E), `Data_Retention_Schedule_2026-07-11.md` (new class 10).

What we want to do

To catch **sock-puppet fraud** — one bad actor (often a competing vendor) spinning up many fake couple accounts to spam a vendor's inbox or drain the token a vendor spends to answer — we need to tell when several "different" accounts are really **the same browser/device**. So, on a **secured (logged-in) account**, we record a **coarse, first-party device identifier**:

- A **random id** generated once in the browser's `localStorage` (like a cookie). It is **NOT** a behavioral/biometric fingerprint — no canvas/font/WebGL probing, no third-party fingerprinting SDK, no cross-site tracking.
- Sent to our own server, where it is **hashed** (SHA-256 with a server-side salt) and stored as `user_devices.device_hash` against the account. **The raw id is never stored** — only the one-way hash.
- Two accounts that share a device produce the **same hash**, which lets our existing fraud-clustering flag them for **human review** (it never auto-bans anyone).

Nothing here is shared with any third party, used for advertising, or used to profile a couple's planning behavior.

The legal basis we're relying on

- **Legitimate interests (RA 10173 §12(f))** — preventing fraud and protecting the integrity of the marketplace (and the vendors who pay us) is a textbook legitimate-interest processing purpose. The data is a **pseudonymous hash**, the least-intrusive signal that achieves the purpose, and it is **not sensitive personal information**.
- Balancing test: the intrusion is minimal (a hashed random id, fraud-only, no tracking), the interest is substantial (vendors are charged per lead; fakes are a direct financial harm), and it is disclosed. We assess legitimate interest as the correct basis rather than consent — **but this is the DPO's call** (see item 1 below).

The seven safeguards built into the design

1. **Coarse by design.** A random `localStorage` id — explicitly **not** a canvas/font behavioral fingerprint and **no external SDK**. It identifies a *browser*, not a *person's* behavior.
2. **Hashed, raw value never stored.** `SHA-256(salt + id)` server-side; the DB holds only the hash. The salt is a server secret.
3. **Purpose limitation.** Used **only** for fraud detection (identity-cluster review). Never for ads, marketing, personalization, or sold.
4. **Secured accounts only.** Anonymous/draft sessions are not captured — no fraud-subject identity, no capture.
5. **Data minimization + first-party only.** One hash per (account, device) + a `last_seen_at`. No IPs stored for this (IP is explicitly out of scope of the cluster signals). No third-party recipients.

6. **Retention clock.** New **class 10** in the retention schedule: kept for fraud-prevention while the account is active, **purged with the account** (class 5 tail); `last_seen_at` enables a rolling prune of stale device rows. Confirm the period (item 3).
7. **Rights honored.** The device hash is account-linked personal data → included in the existing **"download my data"** export and **deleted on account deletion** (iteration 0025). An opt-out is available if the DPO decides consent (not legitimate interest) is required.

What we'd like the DPO to confirm

1. **Legal basis** — that **legitimate interest (fraud prevention)** is the correct basis, so this can be **on-by-default when enabled** with notice; OR direct us to make it **consent-based** (a Privacy-settings toggle, defaulting off).
2. **Notice wording** — proposed privacy-policy line: *"To keep our marketplace safe, we record a hashed identifier for the device you sign in from and use it only to detect fraud and fake accounts. We don't use it for advertising or tracking you across other sites."* Confirm this is adequate.
3. **Retention period** — confirm class 10 (life-of-account + purge-with-account, with a rolling prune of device rows unused for a set period — propose 24 months).
4. Whether a **Privacy-settings entry** (disclosure + optional opt-out) is required in addition to the policy notice.

Engineering state (so the DPO knows the stakes)

Built but switched OFF behind a flag (`NEXT_PUBLIC_DEVICE_FINGERPRINT_ENABLED`, default OFF) — it **cannot collect anything** until the flag is flipped, which we will not do until this sign-off. Fully reversible (flag off → capture stops; existing `user_devices` rows are purgeable). The capture only writes `user_devices`; the fraud-cluster detection it feeds runs in **shadow mode** (admin review only, never auto-action).

Related: `[[dpo-designation-owner]] · Data_Retention_Schedule_2026-07-11.md` (class 10) · `Vendor_Fake_Inquiry_Protection_Build_Plan_2026-07-11.md` (Phase E) · `0025_profile_settings/` (export + deletion + Privacy tab) · `Setnayan_AI_Data_Use_DPO_Review_2026-06-29.md` (sibling DPO one-pager).